



PERFORMANCE WORK STATEMENT (PWS) DEPARTMENT OF VETERANS AFFAIRS

*Office of Information & Technology
Supply Chain Systems Directorate (10NA2)*

Supply Chain GUI Overlay

Date: *February 10, 2025*
VA-26-00023382

PWS Version Number: *1.17*

Contents

1.0	BACKGROUND	4
2.0	APPLICABLE DOCUMENTS	5
3.0	SCOPE OF WORK	8
4.0	PERFORMANCE DETAILS	9
4.1	PERFORMANCE PERIOD	9
4.2	PLACE OF PERFORMANCE	9
4.3	TRAVEL	10
5.0	SPECIFIC TASKS AND DELIVERABLES	10
5.1	PROJECT MANAGEMENT	10
5.1.1	CONTRACTOR PROJECT MANAGEMENT PLAN	10
5.1.2	TECHNICAL KICKOFF MEETING	11
5.2	HUMAN CENTERED DESIGN (HCD) AND APPLICATION PERFORMANCE MONITORING	11
5.2.1	HUMAN CENTERED DESIGN	12
5.2.2	USER RESEARCH	12
5.2.3	CONTENT AND DESIGN	12
5.2.4	PRODUCT LIFECYCLE ACTIVITIES	13
5.2.5	APPLICATION PERFORMANCE MONITORING	13
5.3	SUPPLY CHAIN GUI OVERLAY REQUIREMENTS	13
5.3.1	SOFTWARE REQUIREMENT	13
5.3.2	SERVICES	16
5.3.2.1	MAINTENANCE SUPPORT SERVICES	16
5.4	APAR/APAT TEST INSTANCES AND SUPPORT (OPTIONAL TASK 1)	18
5.4.1.1	TEST ENVIRONMENT MAINTENANCE SUPPORT SERVICES (OPTIONAL TASK 2)	19
5.5	OPTION PERIOD ONE	19
5.6	OPTION PERIOD TWO	19
6.0	GENERAL REQUIREMENTS	20
6.1	ENTERPRISE AND IT FRAMEWORK	20
6.1.1	VA TECHNICAL REFERENCE MODEL	20
6.1.2	ZERO TRUST – VA CRITICAL SECURITY CONTROLS	20
6.1.3	FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)	20
6.1.4	INTERNET PROTOCOL VERSION 6 (IPv6)	22
6.1.5	TRUSTED INTERNET CONNECTION (TIC)	22
6.1.6	STANDARD COMPUTER CONFIGURATION	22
6.1.7	VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM)	23
6.1.8	PROCESS ASSET LIBRARY (PAL)	24
6.1.9	AUTHORITATIVE DATA SOURCES	24
6.1.10	SOCIAL SECURITY NUMBER (SSN) REDUCTION	25
6.1.11	SOFTWARE AND LICENSING REQUIREMENTS	25
6.2	SECURITY AND PRIVACY REQUIREMENTS	26
6.2.1	POSITION/TASK RISK DESIGNATION LEVEL(S)	26

Supply Chain GUI Overlay
VA-26-00023382

6.2.2	CONTRACTOR PERSONNEL SECURITY REQUIREMENTS	26
6.3	METHOD AND DISTRIBUTION OF DELIVERABLES	28
6.4	PERFORMANCE METRICS	28
6.5	FACILITY/RESOURCE PROVISIONS	29
6.6	GOVERNMENT FURNISHED PROPERTY	31
ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED		33
ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/ PRIVACY LANGUAGE.....		39

DRAFT

1.0 BACKGROUND

The Department of Veterans Affairs (VA), Office of Information & Technology (OIT), Product Delivery Services (PDS) strives to provide high quality, effective, and efficient Information Technology (IT) services to those responsible for providing care to the Veterans at the point-of-care as well as throughout all the points of the Veterans' health care in an effective, timely and compassionate manner. VA depends on Information Management/Information Technology (IM/IT) systems to meet mission goals.

The VA, Veterans Health Administration (VHA) deployed a Supply Chain Graphical User Interface (GUI) Overlay to Veterans Information Systems and Technology Architecture (VistA) for users at 141 VA Medical Centers (VAMCs), the *Employee Education Services (EES)*, and the *Consolidated Mail Order Pharmacy (CMOP)*, and a training instance at the Veterans Affairs Acquisition Academy (VAAA). The deployed software package provides a tiered control and implementation of standardized national, Veteran Integrated Service Network (VISN), and VAMC business rules, controls, data management and standardization required to perform the functions relating to VistA's Integrated Funds Distribution, Control Point Activity, Accounting and Procurement (IFCAP); General Inventory Package (GIP); Automated Engineering Management System/Medical Equipment Reporting System (AEMS/MERS); Prosthetics Inventory Package (PIP); Equipment Turn-in (EQUIP); VistA Integration, Revenue and Reporting (VIRR); and Prosthetics and Sensory Aids Services (PSAS). It also provides enterprise reporting and data integration services.

The Contractor shall support installation of an Above Participating ProviderR (APAR)/Above Advanced Prosthetics Acquisition Tool (APAT) test instance connected to a VistA test account to support the integration and testing of enhancements to the IFCAP/GIP to determine any impact to the Supply Chain GUI Overlay. The test instance shall be a non-production instance connected to a VistA test instance within the Compliance Risk and Remediation (CRR) Test Center (Bay Pines), enabling end-to-end validation of IFCAP/GIP modifications to maintain operational continuity across VistA's logistics functions. Further, the test instance of the GUI shall be accessible to remote VA staff distributed around the US. Licensing fees for test environment instances shall be discounted waived, with the Contractor providing maintenance support as defined in PWS 5.3 without help desk services, as help desk services are not required. The test environment shall comply with VA Handbook 6500.5 (2021), VA Handbook 6500.6 (2019), VA Directive 0057 (2020), and NIST SP 800-53 Rev. 5 for security, privacy, and environmental sustainability requirements. For clarification, electronic delivery will be accomplished at installation of the instance and acceptance shortly thereafter, as appropriate.

2.0 APPLICABLE DOCUMENTS

In the performance of the tasks associated with this Performance Work Statement, the Contractor shall comply with the following:

1. 44 U.S.C. § 3541-3549, “Federal Information Security Management Act (FISMA) of 2002”
2. “Federal Information Security Modernization Act of 2014”
3. Federal Information Processing Standards (FIPS) Publication 140-2, “Security Requirements for Cryptographic Modules”
4. FIPS Pub 199. “Standards for Security Categorization of Federal Information and Information Systems,” February 2004
5. FIPS Pub 200, “Minimum Security Requirements for Federal Information and Information Systems,” March 2006
6. FIPS Pub 201-2, “Personal Identity Verification of Federal Employees and Contractors,” August 2013
7. 10 U.S.C. § 2224, "Defense Information Assurance Program"
8. 5 U.S.C. § 552a, as amended, “The Privacy Act of 1974”
9. Public Law 109-461, Veterans Benefits, Health Care, and Information Technology Act of 2006, Title IX, Information Security Matters
10. 42 U.S.C. § 2000d “Title VI of the Civil Rights Act of 1964”
11. VA Directive 0710, “Personnel Security and Suitability Program,” June 4, 2010, <https://www.va.gov/vapubs/index.cfm>
12. VA Handbook 0710, “Personnel Security and Suitability Program,” May 2, 2016, <https://www.va.gov/vapubs/index.cfm>
13. VA Directive and Handbook 6102, “Internet/Intranet Services,” August 5, 2019
14. 36 C.F.R. Part 1194 “Information and Communication Technology Standards and Guidelines,” January 18, 2017
15. Office of Management and Budget (OMB) Circular A-130, “Managing Federal Information as a Strategic Resource,” July 28, 2016
16. 32 C.F.R. Part 199, “Civilian Health and Medical Program of the Uniformed Services (CHAMPUS)”
17. NIST SP 800-66 Rev. 1, “An Introductory Resource Guide for Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule,” October 2008
18. Sections 504 and 508 of the Rehabilitation Act (29 U.S.C. § 794d), as amended, January 18, 2017
19. Homeland Security Presidential Directive (12) (HSPD-12), August 27, 2004
20. VA Directive 6500, “VA Cybersecurity Program,” February 24, 2021
21. VA Handbook 6500, “Risk Management Framework for VA Information Systems VA Information Security Program,” February 24, 2021

Supply Chain GUI Overlay
VA-26-00023382

22. VA Handbook 6500.2, "Management of Breaches Involving Sensitive Personal Information (SPI)," March 12, 2019
23. VA Handbook 6500.5, "Incorporating Security and Privacy into the System Development Lifecycle," March 22, 2010
24. VA Handbook 6500.6, "Contract Security," March 12, 2010
25. VA Handbook 6500.8, "Information System Contingency Planning," April 6, 2011
26. VA Handbook 6500.10, "Mobile Device Security Policy," February 15, 2018
27. VA Handbook 6500.11, "VA Firewall Configuration," August 22, 2017
28. OIT Process Asset Library (PAL), <https://www.va.gov/process/> . Reference Process Maps at <https://www.va.gov/process/maps.asp> and Artifact templates at <https://www.va.gov/process/artifacts.asp>
29. One-VA Technical Reference Model (TRM) (reference at <https://www.va.gov/trm/TRMHomePage.aspx>)
30. VA Directive 6508, "Implementation of Privacy Threshold Analysis and Privacy Impact Assessment," October 15, 2014
31. VA Handbook 6508.1, "Procedures for Privacy Threshold Analysis and Privacy Impact Assessment," July 30, 2015
32. VA Handbook 6510, "VA Identity and Access Management," January 15, 2016
33. VA Directive and Handbook 6513, "Secure External Connections," October 12, 2017
34. VA Directive 6300, "Records and Information Management," September 21, 2018
35. VA Handbook, 6300.1, "Records Management Procedures," March 24, 2010
36. NIST SP 800-37 Rev 2, "Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy," December 2018
37. NIST SP 800-53 Rev. 5, "Security and Privacy Controls for Federal Information Systems and Organizations," September 23, 2020 (includes updates as of 12/10/2020)
38. VA Directive 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," October 26, 2015
39. VA Handbook 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," March 24, 2014
40. OMB Memorandum 05-24, "Implementation of Homeland Security Presidential Directive (HSPD) 12 – Policy for a Common Identification Standard for Federal Employees and Contractors," August 5, 2005
41. OMB Memorandum M-19-17, "Enabling Mission Delivery Through Improved Identity, Credential, and Access Management," May 21, 2019
42. OMB Memorandum, "Guidance for Homeland Security Presidential Directive (HSPD) 12 Implementation," May 23, 2008
43. Federal Identity, Credential, and Access Management (FICAM) Roadmap and Implementation Guidance, December 2, 2011, (NOTE: Part A of the FICAM

Supply Chain GUI Overlay
VA-26-00023382

- Roadmap and Implementation Guidance, v2.0, was replaced in 2015 with an updated Architecture (<https://arch.idmanagement.gov/#what-is-the-ficam-architecture>)
44. NIST SP 800-116 Rev 1, “Guidelines for the Use of Personal Identity Verification (PIV) Credentials in Facility Access,” June 2018
 45. NIST SP 800-63-3, 800-63A, 800-63B, 800-63C, “Digital Identity Guidelines,” updated March 02, 2020
 46. NIST SP 800-157, “Guidelines for Derived PIV Credentials,” December 2014
 47. NIST SP 800-164, “Guidelines on Hardware-Rooted Security in Mobile Devices (Draft),” October 2012
 48. Draft National Institute of Standards and Technology Interagency Report (NISTIR) 7981, “Mobile, PIV, and Authentication,” March 2014
 49. VA Memorandum, VAIQ #7100147, “Continued Implementation of Homeland Security Presidential Directive 12 (HSPD-12),” April 29, 2011 (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>)
 50. IAM Identity Management Business Requirements Guidance document, May 2013, (reference Enterprise Architecture Section, PIV/IAM (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>))
 51. VA Memorandum “Personal Identity Verification (PIV) Logical Access Policy Clarification,” July 17, 2019, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>
 52. Trusted Internet Connections (TIC) 3.0 Core Guidance Documents, <https://www.cisa.gov/publication/tic-30-core-guidance-documents>
 53. OMB Memorandum M-19-26, “Update to the Trusted Internet Connections (TIC) Initiative,” September 12, 2019
 54. OMB Memorandum M-08-23, “Securing the Federal Government’s Domain Name System Infrastructure,” August 22, 2008
 55. Sections 524 and 525 of the Energy Independence and Security Act of 2007, (Public Law 110–140), December 19, 2007
 56. Section 104 of the Energy Policy Act of 2005, (Public Law 109–58), August 8, 2005
 57. Executive Order 13834, “Efficient Federal Operations,” dated May 17, 2018
 58. Executive Order 13221, “Energy-Efficient Standby Power Devices,” August 2, 2001
 59. VA Directive 0058, “VA Green Purchasing Program,” July 19, 2013
 60. VA Handbook 0058, “VA Green Purchasing Program,” July 19, 2013
 61. Office of Information Security (OIS) VAIQ #7424808 Memorandum, “Remote Access,” January 15, 2014, <https://www.voa.va.gov/DocumentListPublic.aspx?NodeId=28>
 62. Clinger-Cohen Act of 1996, 40 U.S.C. §11101 and §11103
 63. “Veteran Focused Integration Process (VIP) Guide 4.0,” January 2021, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371>

Supply Chain GUI Overlay
VA-26-00023382

64. [VA Memorandum “Proper Use of Email and Other Messaging Services,” January 2, 2018, https://www.voa.va.gov/DocumentListPublic.aspx?NodeId=28](https://www.voa.va.gov/DocumentListPublic.aspx?NodeId=28)
65. [“DevSecOps Product Line Management Playbook” version 2.0, May 2021, https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946](https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946)
66. [NIST SP 500-267B Revision 1, “USGv6 Profile,” November 2020](#)
67. [OMB Memorandum M-21-07, “Completing the Transition to Internet Protocol Version 6 \(IPv6\),” November 19, 2020](#)
68. [Social Security Number \(SSN\) Fraud Prevention Act of 2017](#)
69. Section 240 of the Consolidated Appropriations Act (CAA) 2018, March 23, 2018
70. Attachment A – Service Delivery Point (SDP) List
71. Human Centered Design - <https://digital.gov/topics/human-centered-design/>

3.0 SCOPE OF WORK

The Contractor shall provide a renewal of the annual operations and maintenance support for the Supply Chain GUI Overlay enterprise reporting, dashboards, and data integration software packages. 141 VHA facilities and the VAAA, CMOP and EES (sum total quantity of 144 sites) are currently utilizing the solution, with the potential for additional sites/groups to be added through optional tasks.

The operations and maintenance support shall include labor, travel, and expenses for continuation training, operations and maintenance, required system fixes, and software enhancements. The Contractor shall provide both remote and on-site support as required for the GUI and all updates and upgrades during the contract period.

The operations and maintenance support shall cover all the sites nationally and be based upon the VA facility size. The current site size usage is 84 Large, 26 Medium, and 33 Small facility sizes and 1 VAAA (a total of 144 sites) utilizing the GUI product.

Optional tasks: if exercised by the Government, the Contractor shall provide renewed licenses for test accounts for APAR and APAT. These test accounts will be used to test potential VistA changes due to other VA programs, such as, but not limited to the Electronic Health Record Modernization effort, any newly approved VA modernized Medical Records solution, and/or Financial Management Business Transformation (FMBT) Integrated Financial and Acquisition Management System (iFAMS) program. These test instances will be used to identify how potential VistA changes may impact APAR and APAT usage, and includes code review of MUMPS code.

4.0 PERFORMANCE DETAILS

4.1 PERFORMANCE PERIOD

The proposed Period of Performance shall be 12 months with two subsequent 12-month option periods and two optional tasks, if exercised. Any Optional Tasks, if exercised, shall coincide with the period of performance in which they are exercised and will be prorated to not extend past the completion date of the period in which it is potentially exercised. In no event shall the period of performance extend past 36 months.

Except for critical coverage maintenance support services required in section 5.3.2.1, any work at the Government site shall not take place on Federal holidays or weekends unless directed by the Contracting Officer (CO).

There are 11 Federal holidays set by law (USC Title 5 Section 6103) that VA follows:

Under current definitions, five are set by date:

New Year's Day	January 1
Juneteenth	June 19
Independence Day	July 4
Veterans Day	November 11
Christmas Day	December 25

If any of the above falls on a Saturday, then Friday shall be observed as a holiday. Similarly, if one falls on a Sunday, then Monday shall be observed as a holiday.

The other six are set by a day of the week and month:

Martin Luther King's Birthday	Third Monday in January
Washington's Birthday	Third Monday in February
Memorial Day	Last Monday in May
Labor Day	First Monday in September
Columbus Day	Second Monday in October
Thanksgiving	Fourth Thursday in November

4.2 PLACE OF PERFORMANCE

Tasks under this PWS shall be performed at Contractor facilities. The Contractor shall identify the Contractor's place of performance in their proposal submission. Performance shall not be permitted outside the United States or its territories.

4.3 TRAVEL

The Government anticipates travel under this effort to perform the tasks associated with the effort, as well as to attend program-related meetings or conferences throughout the PoP. Include all estimated travel costs in your firm-fixed price line items. These costs will not be directly reimbursed by the Government.

The total estimated number of trips in support of the program related meetings for this effort is 3 estimated trips. Anticipated locations include the following, estimated at 3 days including travel to the facility in duration:

Period	Site	Location	# Trips	# People	Duration
Base	VA Headquarters	Washington, D.C. or West Palm, FL	Up to 1	4	3 days
Option Period 1	VA Headquarters	Washington, D.C. or West Palm, FL	Up to 1	4	3 days
Option Period 2	VA Headquarters	Washington, D.C. or West Palm, FL	Up to 1	4	3 days

Travel shall be in accordance with the Federal Travel Regulations (FTR) (<https://www.gsa.gov/policy-regulations/regulations/federal-travel-regulation>) and requires advanced concurrence by the COR. Contractor travel within the local commuting area will not be reimbursed.

5.0 SPECIFIC TASKS AND DELIVERABLES

The Contractor shall perform the following:

5.1 PROJECT MANAGEMENT

5.1.1 CONTRACTOR PROJECT MANAGEMENT PLAN

The Contractor shall deliver a Contractor Project Management Plan (CPMP) that lays out the Contractor's approach, timeline, and tools to be used in execution of the contract. The CPMP should take the form of both a narrative and graphic format that displays the schedule, milestones, risks, and resource support. The CPMP shall also include how the Contractor shall coordinate and execute planned, routine, and ad hoc data collection reporting requests as identified within the PWS. The initial baseline CPMP shall be concurred upon and updated in accordance with Section B/Price

Schedule of the resultant contract. The Contractor shall update and maintain the VA PM approved CPMP throughout the PoP.

Deliverable:

- A. Contractor Project Management Plan

5.1.2 TECHNICAL KICKOFF MEETING

A technical kickoff meeting shall be scheduled within 10 days after TO award and held within 330 days of award. The Contractor shall coordinate the date, time, and location (can be virtual) with the Contracting Officer (CO), as the Post-Award Conference Chairperson, the VA Program Manager (PM), as the Co-Chairperson, the Contract Specialist (CS), and the Contracting Officer's Representative (COR). The Contractor shall provide a draft agenda to the CO and VA PM at least five (5) days prior to the meeting. Upon Government approval of the final agenda, the Contractor shall distribute to all meeting attendees. During the kickoff-meeting, the Contractor shall present, for review and approval by the Government, the details of the intended approach, work plan, and project schedule for each effort via a Microsoft Office PowerPoint presentation. At the conclusion of the meeting, the Contractor shall update the presentation with a final slide entitled "Summary Report" which shall include notes on any major issues, agreements, or disagreements discussed during the kickoff meeting and the following statement "As the Post-Award Conference Chairperson, I have reviewed the entirety of this presentation and assert that it is an accurate representation and summary of the discussions held during the Technical Kickoff Meeting for the Supply Chain GUI Overlay." The Contractor shall submit the final updated presentation to the CO for review and signature within three (3) days after the meeting. The Contractor shall also work with the CS, the Government's designated note taker, to prepare and distribute the meeting minutes of the kickoff meeting to the CO, COR and all attendees within three (3) days after the meeting. The Contractor shall obtain concurrence from the CS on the content of the meeting minutes prior to distribution of the document.

Deliverable:

- A. Agenda
- B. Kickoff Meeting Minutes
- C. Kickoff Meeting PowerPoint Presentation

5.2 HUMAN CENTERED DESIGN (HCD) AND APPLICATION PERFORMANCE MONITORING

5.2.1 HUMAN CENTERED DESIGN

The Contractor shall utilize Human Centered Design (HCD) principles as part of all product development and operations efforts. While engaging in the following HCD activities, the Contractor shall:

1. Follow the United States Digital Service value: “Design with users, not for them.”;
2. Provide expert guidance on user experience (UX) design direction and strategy; and
3. Create and maintain documentation for all activities, recommendations, and decisions.

At the start of work on Supply Chain GUI Overlay enhancements, the Contractor shall conduct a product development review with government Product Owner and designated stakeholders to establish desired outcomes.

5.2.2 USER RESEARCH

As part of the user research, the Contractor shall:

- A. Facilitate discovery activities, to include generative research with users and business stakeholders, an assessment of current related features, a content review, an information architecture review, an accessibility review, a business process review, and collection of any available data and analytics.
- B. Partner with other VA Product Teams to ensure that updates and functionality enhancements fit into the existing structure
- C. Conduct formative and contextual user research studies to understand users’ goals, needs, journeys, and pain points with respect to the Supply Chain GUI Overlay. Apply insights from user research studies to define minimum viable product (MVP) functionality, including epics and user stories, as well as operational, business, functional, technical, data, and integration requirements.
- D. As part of the overall product test strategy, conduct routine, iterative usability testing to continually improve the user experience and to inform content, information architecture, design, functionality, and accessibility. Iteratively apply insights gathered to inform design and development.
- E. Before releasing to production, conduct user acceptance testing on new features, content reviews of existing content, Information Architecture reviews for global navigation and design reviews of existing patterns and User Interface elements to identify and make modifications while maintaining a positive user experience.

5.2.3 CONTENT AND DESIGN

- A. Employ design process management by breaking designs into small, bite-sized implementations and collecting data from each deployment to inform priorities and decisions in the next iteration.

- B. Ensure consistency and continuity in Supply Chain GUI Overlay information architecture, including URL schema, page layout, menus and navigation, user flows, and search engine optimization. Work with all VA Product Teams to incorporate updates and functionality enhancements, both authenticated and unauthenticated content and tools, into the Information Architecture Document of Supply Chain GUI Overlay.
- C. Support and comply with all UX guidelines and standards as defined by the VA, currently at <https://department-of-veterans-affairs.github.io/va-digital-service-handbook/>

5.2.4 PRODUCT LIFECYCLE ACTIVITIES

The Contractor shall support HCD activities for the Supply Chain GUI Overlay through its lifecycle by engaging in the following activities:

- A. Conduct discovery activities on existing Supply Chain GUI Overlay as well as internal and external business process flows and functions. Work closely with VA customers to understand their needs and how those needs map to VA capabilities. Collect available data, user feedback, and VA stakeholder feedback and capture in a Discovery Report to be delivered within 15 days of a change event/review.
- B. Participate in VA stakeholder meetings, some of which will be in-person at VA facilities, to plan building and integrating the services and change management activities.

Deliverable:

- A. Discovery Report

5.2.5 APPLICATION PERFORMANCE MONITORING

As part of Supply Chain GUI Overlay, the Contractor shall assist VA with Application Performance Monitoring strategies for application health and performance.

The Contractor shall provide input on the Application Monitoring Plan that defines how metrics will be monitored throughout the performance of the requirements, including the automated testing tools and automated Service Level Agreement (SLA) testing scripts that shall be used. All Performance Monitoring Strategies and the Application Monitoring Plan must be approved by the Program Manager and Contracting Officer.

5.3 SUPPLY CHAIN GUI OVERLAY REQUIREMENTS

5.3.1 SOFTWARE REQUIREMENT

The Contractor shall continue to support its commercially available off-the-shelf (COTS) Supply Chain GUI Overlay, reporting, dashboards, and data integration software solution for immediate use. The Contractor's solution must continue to demonstrate the

capability to interface with VistA's application modules. The licensing and maintenance must continue to support the following functions at a minimum:

- A. Work Order Entry, Audit, Tracking, & Reporting
 - 1. Enter work order
 - 2. Assign work order
 - 3. Document a work order, including attachment of files
 - 4. Close a work order
 - 5. Edit a work order, open or closed
 - 6. Audit work order fields
 - 7. Limit access to certain work order fields based on system user role
 - 8. Require certain fields
 - 9. View purchase orders
- B. Equipment Inventory Entry, Audit, Tracking, & Reporting
 - 1. Enter a new equipment record
 - 2. Edit equipment records
 - 3. Audit equipment fields
 - 4. Limit access to fields based on user role
 - 5. Require certain fields
 - 6. Generate incoming inspection work order from equipment record
 - 7. Generate turn-in requests
 - 8. Approve turn-in requests and disposition equipment
 - 9. View purchase orders
 - 10. Generate Fixed Asset Package (FAP) documents for equipment
 - 11. Enter multiple equipment items
- C. Inventory Package Entry, Audit, Tracking, & Reporting
 - 1. View inventory point information
 - 2. Provide stock status information
 - 3. Receive supplies into an inventory point
 - 4. View purchase order information
- D. Prosthetic Software Package
 - 1. Create request for quotes for Prosthetic devices and/or services.
(referred to as VA Form FL 10-90; with fax cover sheets)
 - 2. Multiple quotes for an item can be created at the same time to different vendors providing time savings.
 - 3. Quotes are retained in the system for easy retrieval if they need to be re-sent to vendors.
 - 4. Consult information can be easily copied/pasted into the Fax cover sheet, reducing manual data entry.
 - 5. All 10-90 information is displayed and saved with VistA.

Supply Chain GUI Overlay
VA-26-00023382

6. Create new Purchase Order and integrate with historic purchase orders in VistA.
7. Allows PO to be easily re-sent to vendor if needed.
8. Consult information can be easily copied/pasted into the purchase order if needed (i.e., optometry orders)
9. VistA integration to all appropriate packages (VistA Prosthetics Package to include posting to the Record of Prosthetic Appliance and Repair (VAF-2319), Computerized Patient Record System (CPRS) Consult/Request Tracking, IFCAP, and National Prosthetic Patient Database (NPPD)).
10. Enforce/Alert to mandatory data fields when creating purchase orders or stock issues.
11. Scan, index, and upload all other paperwork collected by the purchasing agents. All documentation is stored in a document library within VA infrastructure for future document retrieval. VA documentation storage location will be identified by the PM and COR after award. This includes electronic images, such as pictures required for Home Improvement and Structural Alteration Program (HISA). The solution shall allow each individual VA facility the ability to define what types of documents they want to store such as paperwork for Clothing Allowances, HISA documents (including pictures), Automobile Adaptive Equipment (AAE) documents, Packing Slips, invoices and quotes.
12. Index documents based on Patient, Vendor, or Purchase Order and allow easy retrieval of data
13. Retains all images in the document library IAW VA record management. This provides savings on storage space and potential off-site costs.
14. Bid and purchase order information can be sent to a fax server program utilized by VA, Enterprise Cloud Fax (currently ECFax.Gov). Create, assign, and edit the Orthotic Laboratory Work orders (OWL). The proposed solution shall allow users to manage these functions all in one location/ place.
15. Provide a feature that allows the user to view VAF-2319 information from multiple VA medical centers within the current business workflow to prevent fraud, waste and abuse. The centralized data is then accessible by the local applications and will eventually be available for national reporting.
16. All VistA Prosthetics GUI functions as listed in PWS section 5.3.1 can be performed including VistA GUI reports.

17. Create Detailed PO to order Prosthetics Stock inventory (that will be managed in GIP)
18. Create Stock Issue to Veteran patient of Prosthetics item
19. Extract feature to permit the export of Prosthetics encounter information used by the VA Health Information Management Systems (HIMS) and Chief Business Office (CBO) for coding and billing. This will help all encounters are appropriately entered into revenue cycle stream.
20. PSAS Reporting to include:
 - a. Provides standardized and Ad Hoc reports.
 - b. All fields in the purchase order are catalogued for reporting. For example, serial number can be queried in an ad hoc report for recalls if needed.
 - c. Reporting on number of quotes and purchase orders generated
 - d. Ad hoc reporting capabilities allow users to define the type of data needed (i.e. any field that exists on the purchase order)
 - e. All reports can be exported to Excel

5.3.2 SERVICES

The Contractor shall provide the below services for this effort:

5.3.2.1 MAINTENANCE SUPPORT SERVICES

The Contractor's maintenance support services provided under this effort shall meet the following:

- A. Hours of Coverage at each VAMC as identified in Attachment A:
 1. Routine Coverage: Monday through Friday, 8:00 AM to 8:00 PM ET.
 2. Critical Coverage: 7-days per week; 24 hours per day, 365 days per year. Critical issues are urgent incidents or a catastrophic incident of an operating environment where production systems are severely impacted, down, or not functioning or an issue which may impact patient care or patient safety. Response time shall align with VA/OIT 'Major Incident Management Process' criteria for priority 1 and/or priority 2 outages.
- B. The Contractor shall provide the following:

Supply Chain GUI Overlay
VA-26-00023382

1. Web-enabled Help Desk support & services to report, track, remedy, and escalate (if necessary) work ticket requests shall be included.
2. Maintenance and software fixes/repair of the system shall be included.
3. Updates, upgrades, and functionality enhancements shall be included. This task is also subject to the requirements under PWS 5.3.1 and 5.3.2.
4. Deployment and installation support and training shall be included to ensure software is installed, tested, and operational.

C. **Guaranteed Uptime:** The Contractor shall guarantee 98% uptime of the installed GUI Overlay applications, 24 hours a day, seven days a week, 365 days per year, excluding downtime caused by VA system or hardware failures.

D. **Updates And Functionality Enhancements:** The Contractor shall provide system engineering changes, updates, and functionality enhancements coordinated through the Office of Information Technology for review, test and approval to release. This shall include any changes/patches/bug fixes and deliverables to include (Deployment Guide, Release Notes, Test Site Preparation Checklist, and User Acceptance Test (UAT) Test cases and scripts.

E. **Qualifications:** The COR will authenticate the training requirements, request training certificates or credentials from the contractor at any time for any personnel who are servicing or installing any software or conducting training. All service personnel will be aware of and compliant with Hospital policy and procedures pertaining to safety, fire, severe weather, and emergency procedures.

The Contractor shall have an approved National Business Associates Agreement (BAA). (Refer to Section 6.2)

The Contractor shall adhere to all Information Security requirements as outline in VA Directive 6500. All servicing personnel shall be required to get background investigations. (Refer to Sections 6.2.1 and 6.2.2)

F. **National Coordination, Tracking, And Approval:** The Contractor shall coordinate with the COR/OIT for recording and tracking of all GUI Overlay requirements, software changes and enhancements. The Contractor shall ensure that all software patches shall be released in accordance with VA's SDLC process. The Contractor shall remove code from any patches that is deemed harmful, untested or unapproved by VA (specifically VHA Logistics and Prosthetics SMEs) within 12 hours of notification.

H. **Documentation Requirements:** The Contractor shall provide the COR with a Technical Services Monthly Report in electronic form in Microsoft Word or Adobe PDF formats. The report shall include detailed information on the work

Supply Chain GUI Overlay
VA-26-00023382

completed by the technical services support team (help desk) each month. That support includes calls made directly to the vendor or work that was transferred by the VA Enterprise Service Desk. The report shall also include metrics on the number of help desk tickets and the disposition/status of the tickets in each reporting month.

I. Training: Training shall be included to ensure that users are trained in the capabilities and operation of the software. The Contractor shall at a minimum:

- a. Develop training materials to include manuals and videos based on the roles and functionality in the GUI product.
- b. Create the artifacts for every patch version/release.

Deliverable:

- A. Technical Services Monthly Report
- B. Role and functionality-based training materials (including manuals and videos) for each patch version/release
- C. Deployment Plan
- D. Release Notes
- E. Test Site Preparation Checklist
- F. User Acceptance Test (UAT) Test Cases and Scripts

5.4 APAR/APAT TEST INSTANCES AND SUPPORT (OPTIONAL TASK 1)

The Contractor shall support licensing of APAR/APAT test instance(s) connected to a VistA test account to support the integration and testing of enhancements to the IFCAP/GIP to determine any impact to the Supply Chain GUI Overlay. The test instances (Quantity of 1 for each application) shall be a non-production instance connected to a VistA test instance within the Compliance Risk and Remediation (CRR) Test Center (Bay Pines), enabling end-to-end validation of IFCAP/GIP modifications to maintain operational continuity across VistA's logistics functions. Further, the test instance of the GUI shall be accessible to remote VA staff distributed around the US. The Contractor providing maintenance support as defined in PWS 5.3 without help desk services, as help desk services are not required. The test environment shall comply with VA Handbook 6500.5 (2021), VA Handbook 6500.6 (2019), VA Directive 0057 (2020), and NIST SP 800-53 Rev. 5 for security, privacy, and environmental sustainability requirements. For clarification, electronic delivery will be accomplished at installation of the instance and acceptance shortly thereafter, as appropriate.

Deliverable:

- A. Test Instance of APAR
- B. Test Instance of APAT

5.4.1.1 TEST ENVIRONMENT MAINTENANCE SUPPORT SERVICES (OPTIONAL TASK 2)

If exercised, the Contractor shall provide maintenance support services for test instances provided under this effort which shall meet the following criteria:

1. Hours of Coverage for the Test Environment is expected to be routine coverage of Monday through Friday, 8:00 AM ET to 8:00 PM ET.
1. Guaranteed 98% uptime of the Above PAR and APAT software during testing events. Uptime of 98% during scheduled test events.
2. The Contractor shall provide technical support to address installation issues.
3. The Contractor shall support configuration of the test environment to mirror the production environment's functionality, ensuring seamless integration with VISTA's logistics modules.
4. The Contractor shall collaborate with the VA Project Manager (PM) and Contracting Officer's Representative (COR) to ensure the test environment supports testing activities and can be used to evaluate IFCAP/GIP impacts on the GUI
5. The Contractor shall collaborate with VA on the creation of the Test Data Artifact. provide new test system supply chain/patient data sets for testing.
6. The Contractor shall provide monthly reviews of IFCAP/GIP MUMPS code changes due to implementation of the iGIVE or iFAMS modernization/integration efforts and provide a Code Review Analysis Report including what code (i.e., IFCAP/GIM, iFIVE, iFAMS, etc.) was analyzed, method for analysis and findings indicating if there are no impacts or containing a list of corresponding requirements for Supply Chain GUI Overlay updates needed to ensure operational integrity. The Contractor shall also provide a Level of Effort (LOE) if a list of requirements is provided in the report. NO PRODUCTION ENHANCEMENTS WILL BE REQUESTED AS PART OF THIS REQUIREMENT.

Deliverables:

- A. Code Review Analysis Report

The Contractor shall perform all tasks outlined in the PWS Sections 5.3.2.1. All deliverables produced under 5.3.2.1 shall be updated as a result of the Optional Task being exercised.

5.5 OPTION PERIOD ONE

If exercised, the Contractor shall perform tasks 5.1 through 5.3 including all subtasks.

5.6 OPTION PERIOD TWO

If exercised, the Contractor shall perform tasks 5.1 through 5.3 including all subtasks.

6.0 GENERAL REQUIREMENTS

6.1 ENTERPRISE AND IT FRAMEWORK

6.1.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall comply with the VA OIT Technical Reference Model (VA TRM). Compliance with the VA TRM is achieved by using only technologies and standards that are listed as approved for use in the VA TRM. The Contractor shall provide all necessary information requested by VA to ensure TRM approval is obtained prior to use on VA's network.

6.1.2 ZERO TRUST – VA CRITICAL SECURITY CONTROLS

VA has established minimum mandatory security requirements and requires that any network connected software system or service must meet the VA Critical Security Controls as outlined in the VA Memorandum, "VA Security Controls", <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>. VA Critical Security Controls identify the minimum mandatory requirements that must be implemented across all VA enterprise infrastructure, cloud computing environments, information systems, networks, and specialized devices (medical devices/systems, special-purpose systems, and research scientific computing devices) that process, store, and/or transmit VA data. Effective July 1, 2025, the Contractor shall implement these VA Critical Security Controls, within any network connected software system or service prior to being authorized for use in the VA. This functional requirement is not negotiable, and Plan of Action & Milestones (POAM) will not be accepted in the event these controls cannot be implemented for new systems. Critical Security Controls are intended to increase VA's security posture and provide security and privacy risk visibility into the VA network and is not a new requirement. The Contractor's failure to maintain these VA Critical Controls after implementation will result in VA discontinuing the use of the system.

6.1.3 FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)

The Contractor shall ensure Commercial Off-The-Shelf (COTS) product(s), software configuration and customization, and/or new software are Personal Identity Verification (PIV) card-enabled by accepting HSPD-12 PIV credentials using [VA Enterprise Architecture \(EA\)](#), and VA Identity and Access Management (IAM) approved [Enterprise Technology Guidelines \(ETG\)](#). The Contractor shall ensure all Contractor delivered applications and systems comply with the VA Identity, Credential, and Access Management policies and guidelines set forth in Executive Order 14028, VA Handbook 6510 VA Identity and Access Management, VA Handbook 0735 Homeland Security Presidential Directive 12 (HSPD-12) Program, CISA Binding Operational Directive 23-

Supply Chain GUI Overlay
VA-26-00023382

01, and align with the Federal Identity, Credential, and Access Management Roadmap and Implementation Guidance v2.0.

The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-63-3, VA Handbook 6500, and VA IAM enterprise requirements for direct, assertion-based authentication, and/or trust based authentication, as determined by the ETGs. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV card and/or Common Access Card (CAC), as determined by the business need.

The Contractor shall ensure all Contractor delivered applications and systems conform to the specific Identity and Access Management PIV requirements set forth in the Office of Management and Budget (OMB) Memoranda [M-05-24](#), [M-19-17](#), [M-22-09](#), and NIST Federal Information Processing Standard (FIPS) 201-3. Contractor delivered applications and systems shall be on the FIPS 201 Approved Product List (APL). If the Contractor delivered application and system is not on the APL, the Contractor shall be responsible for taking the application and system through the FIPS 201 Evaluation Program.

The Contractor shall ensure all Contractor delivered applications and systems support:

1. Automated provisioning and are able to use enterprise provisioning service.
2. Interfacing with VA's Master Person Index (MPI) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
3. The VA defined unique identity (Secure Identifier [SEC ID] / Integrated Control Number [ICN]).
4. Multiple authenticators for a given identity and authenticators at every Authenticator Assurance Level (AAL) appropriate for the solution.
5. Identity proofing for each Identity Assurance Level (IAL) appropriate for the solution.
6. Federation for each Federation Assurance Level (FAL) appropriate for the solution, if applicable.
7. Two-factor authentication (2FA) through an applicable Technology Guideline as outlined in VA ETG.
8. A Security Assertion Markup Language (SAML) implementation if the solution relies on assertion-based authentication. Additional assertion implementations, besides the required SAML assertion, may be provided as long as they are compliant with NIST SP 800-63-3 guidelines.
9. Authentication/account binding based on trusted Hypertext Transfer Protocol (HTTP) headers if the solution relies on Trust based authentication.
10. Role Based Access Control.
11. Auditing and reporting capabilities.
12. Compliance with VIEWS 00155984, PIV Logical Access Policy Clarification <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>.

The required Assurance Levels for this specific effort are Identity Assurance Level 3, Authenticator Assurance Level 3, and Federation Assurance Level 3.

6.1.4 INTERNET PROTOCOL VERSION 6 (IPv6)

The Contractor solution shall support IPv6-Only based upon the memo issued by the Office of Management and Budget (OMB) on November 19, 2020 (<https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf>). Which defines IPv6-only as the state of an operational system or service when IPv4 protocol functions (addressing, packet forwarding) are not in use. The NIST USGv6 profile defines technical requirements for a product to be capable of operating in IPv6-Only environments. IPv6-Only technology, in accordance with the USGv6 Program (<https://www.nist.gov/programs-projects/usgv6-program/usgv6-revision-1>), NIST Special Publication (SP) 500-267B Revision 1 "USGv6 Profile" (<https://doi.org/10.6028/NIST.SP.500-267Br1>), and NIST SP 800-119 "Guidelines for the Secure Deployment of IPv6" (<https://doi.org/10.6028/NIST.SP.800-119>), compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices, applications, and systems shall support all applicable functionality on native IPv6-Only as well as dual stack (IPv6 / IPv4) connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g., web, email, DNS, ISP services, etc.) shall support native IPv6-Only and dual stack (IPv6 / IPv4) users and all internal infrastructure and applications shall support using native IPv6-Only and dual stack (IPv6 / IPv4) for all functionality and operations.

6.1.5 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, "Update to the Trusted Internet Connections (TIC) Initiative" (<https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf>), VA Directive 6513 "Secure External Connections", and shall comply with the TIC 3.0 Core Guidance Documents, including all Volumes and TIC Use Cases, found at the Cybersecurity & Infrastructure Security Agency (CISA) (<https://www.cisa.gov/publication/tic-30-core-guidance-documents>).

6.1.6 STANDARD COMPUTER CONFIGURATION

The Contractor IT end user solution that is developed for use on standard VA computers shall be compatible with and be supported on the standard VA operating system, Windows 10 (64bit) and Windows 11, Edge (Chromium based), and 365 Apps for enterprise. Applications delivered to VA and intended to be deployed to Windows 10

and or Windows 11 workstations shall be delivered as a signed .msi package with switches for silent and unattended installation and updates shall be delivered in signed .msp file formats for easy deployment using Microsoft Endpoint Configuration Manager (CM) VA's current desktop application deployment tool. Signing of the software code shall be through a vendor provided certificate that is trusted by VA using a code signing authority such as Verizon/Cybertrust or Symantec/VeriSign. The Contractor shall also ensure and certify that their solution functions as expected when used from a standard VA computer, with non-admin, standard user rights that have been configured using the Defense Information Systems Agency (DISA) Secure Technical Implementation Guide (STIG) specific to the particular client operating system being used.

6.1.7 VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM)

The Contractor shall support VA efforts IAW the Veteran-Focused Integration Process (VIP) Guide and Product Line Management (PLM) Playbook. The major focus of VIP is on Enterprise Oversight, Governance, reporting, and establishing practices that focus on outcomes and continuously delivering sustainable IT capabilities to benefit the Veteran. PLM is a framework that focuses on delivering functional products that provide the highest priority work to customers while delivering simplified, reliable, and practical solutions to the business, medical staff, and our Veterans. The VIP Guide is a companion guide to the PLM Transformation Playbook and can be found at: <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371> and the PLM Transformation Playbook can be found at <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>. VIP and PLM are the authoritative processes that IT projects must follow to ensure development and delivery of IT products.

The VIP Guide provides guidance for transitioning from project-centric to product-centric delivery. The VIP guide applies to all OIT Office of Management and Budget (OMB) reportable products that are required to collect and report costs, schedules, risks, and other valuable information in VA PARS (whether products are procured or developed by VA) and any VA Information Technology project effort in Software Product Management (SPM) and Infrastructure Operations (IO), or their successors, that touch the VA network regardless of IT organizational alignment (whether it spends government funding from VA's Congressional IT Appropriation or any other appropriation).

The PLM Transformation Playbook details how OIT leadership expects Product Lines (PLs) to implement PLM, DevOps, and Lean-Agile principles, methods, practices, and techniques through levels of maturity. The PLM Transformation Playbook applies to all Information Technology (IT) products aligned to PLs in the Software Product Management, Infrastructure Operations and Product Engineering organizations within the OIT organization.

Others outside the referenced groups or organizations may use the VIP Guide and PLM Transformation Playbook for situational awareness as needed.

6.1.8 PROCESS ASSET LIBRARY (PAL)

The Contractor shall perform their duties consistent with the processes defined in the OIT Process Asset Library (PAL). The PAL includes a spectrum of OIT functions and activities, such as project management, operations, service delivery, communications, acquisition, and resource management. PAL serves as an authoritative and informative repository of searchable processes, activities or tasks, roles, artifacts, tools and applicable standards and guides to assist the OIT workforce, Government and Contractor personnel. OIT utilizes PAL processes to ensure compliance with policies and regulations and to meet VA quality standards. The PAL includes the contractor onboarding process consistent with Section 6.2.2 and can be found at [process CONB ext.docx \(live.com\)](#). The main PAL can be accessed at www.va.gov/process.

6.1.9 AUTHORITATIVE DATA SOURCES

The VA Enterprise Architecture Repository (VEAR) is one component within the overall EA that establishes the common framework for data taxonomy for describing the data architecture used to develop, operate, and maintain enterprise applications. The Contractor shall comply with the department's Authoritative Data Source (ADS) requirement that VA systems, services, and processes throughout the enterprise shall access VA data solely through official VA ADSs where applicable, see below. The Information Classes which compose each ADS are located in the VEAR, in the Data & Information domain. The Contractor shall ensure that all delivered applications and system solutions support:

1. Interfacing with VA's Master Person Index (MPI) (formerly the Master Veteran Index (MVI)) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
2. Interfacing with Capital Asset Inventory (CAI) to conduct real property record management actions, if the solution relies on real property records data. CAI is the authoritative source for VA real property record management data.
3. Interfacing with electronic Contract Management System (eCMS) for access to contract, contract line item, purchase requisition, offering vendor, and solicitation information above the micro-purchase threshold, if the solution relies on procurement data. ECMS is the authoritative source for VA procurement actions data.
4. Interfacing with HRSmart Human Resources Information System to conduct personnel action processing, on-boarding, benefits management, and compensation management, if the solution relies on personnel data. HRSmart is the authoritative source for VA personnel information data.

5. Interfacing with VA Profile to access personal contact information, if the solution relies on VA Veteran personal contact information data. VA Profile is the authoritative source for VA Veteran Personal Contact Data.
6. Interfacing with VA/Department of Defense (DoD) Identity Repository (VADIR) for determining eligibility for VA benefits under Title 38, if the solution relies on qualifying active duty military service data. VADIR is the authoritative source for qualifying active duty military service in VA.
7. Interfacing with VA Systems Inventory (VASI) to access VA systems information, if the solution relies on VA system information. VASI is the authoritative source for VA Information Technology systems.
8. Interfacing with Enterprise Mission Assurance Support Service (eMASS) to access the Authority to Operate (ATO) status of all VA Information Systems. eMASS contains the official Authority to Operate (ATO) status of all VA Information Systems.

6.1.10 SOCIAL SECURITY NUMBER (SSN) REDUCTION

The Contractor solution shall support the Social Security Number (SSN) Fraud Prevention Act (FPA) of 2017 which prohibits the inclusion of SSNs on any document sent by mail. The Contractor support shall also be performed in accordance with Section 240 of the Consolidated Appropriations Act (CAA) 2018, enacted March 23, 2018, which mandates VA to discontinue using SSNs to identify individuals in all VA information systems as the Primary Identifier. The Contractor shall ensure that any new IT solution discontinues the use of SSN as the Primary Identifier to replace the SSN with the Integrated Control Number (ICN) in all VA information systems for all individuals. The Contractor shall ensure that all Contractor delivered applications and systems integrate with the VA MPI for identity traits to include the use of the ICN as the Primary Identifier. The Contractor solution may only use a Social Security Number to identify an individual in an information system if and only if the use of such number is required to obtain information VA requires from an information system that is not under the jurisdiction of VA.

6.1.11 SOFTWARE AND LICENSING REQUIREMENTS

The Contractor shall be responsible for the provision of all software licenses and any associated licensing maintenance required for any development, delivery, integration, operation, and/or maintenance associated with its proposed application(s), software products, software solution, and/or system including, but not limited to, any and all application(s), software and/or software products that comprise, are a part of, or integrate with the Contractor's proposed application(s), software products, software solution, and/or system for the life of any resulting contract.

6.2 SECURITY AND PRIVACY REQUIREMENTS

It has been determined that protected health information may be disclosed or accessed, and a signed Business Associate Agreement (BAA) shall be required. The Contractor shall adhere to the requirements set forth within the BAA, referenced in Section D of the resultant contract, and shall comply with VA Directive 6066.

6.2.1 POSITION/TASK RISK DESIGNATION LEVEL(S)

In accordance with VA Handbook 0710, Personnel Security and Suitability Program, the position sensitivity and the level of background investigation commensurate with the required level of access for the following tasks within the PWS are:

Position Sensitivity and Background Investigation Requirements by Task

Task Number	Tier1 / Low Risk	Tier 2 / Moderate Risk	Tier 4 / High Risk
5.1	☐	☒	☐
5.2	☐	☒	☐
5.3	☐	☒	☐
5.4	☐	☒	☐
5.5	☐	☒	☐
5.6	☐	☒	☐

The Tasks identified above, and the resulting Position Sensitivity and Background Investigation requirements identify, in effect, the Background Investigation requirements for Contractor individuals, based upon the tasks the particular Contractor individual will be working. The submitted Contractor Staff Roster must indicate the required Background Investigation Level for each Contractor individual based upon the tasks the Contractor individual will be working, in accordance with their submitted proposal.

6.2.2 CONTRACTOR PERSONNEL SECURITY REQUIREMENTS

Contractor Responsibilities:

- a. The Contractor shall prescreen all personnel requiring access to the computer systems to ensure they maintain the appropriate Background Investigation, and are able to read, write, speak, and understand the English language.
- b. Within 3 business days after award, the Contractor shall provide a roster of Contractor and Subcontractor employees to the COR to begin their background investigations in accordance with the PAL template artifact. The Contractor Staff Roster shall contain the Contractor's Full Name, Date of Birth, Place of Birth, individual background investigation level requirement (based upon Section 6.2 Tasks), etc. The Contractor shall submit full Social Security Numbers either within the Contractor Staff Roster or under separate

Supply Chain GUI Overlay
VA-26-00023382

cover to the COR. The Contractor Staff Roster shall be updated and provided to VA within 1 day of any changes in employee status, training certification completion status, Background Investigation level status, additions/removal of employees, etc. throughout the Period of Performance. The Contractor Staff Roster shall remain a historical document indicating all past information and the Contractor shall indicate in the Comment field, employees no longer supporting this contract. The preferred method to send the Contractor Staff Roster or Social Security Number is by encrypted e-mail. If unable to send encrypted e-mail, other methods which comply with FIPS 140-2 (or its successor) are to encrypt the file, use a secure fax, or use a traceable mail service. (Note that by September 22, 2026, all FIPS 140-2 certificate validations will be placed on the Historical List. See FIPS Transition Effort Timeline for more details: <https://csrc.nist.gov/projects/fips-140-3-transition-effort#schedule>)

- c. The Contractor should coordinate with the location of the nearest VA fingerprinting office through the COR. Only electronic fingerprints are authorized. The Contractor shall bring their completed Security and Investigations Center (SIC) Fingerprint request form with them (see paragraph d.4. below) when getting fingerprints taken.
- d. The Contractor shall ensure the following required forms are submitted to the COR within 5 days after contract award:
 - 1) Optional Form 306
 - 2) Self-Certification of Continuous Service
 - 3) VA Form 0710
 - 4) Completed SIC Fingerprint Request Form
- e. The Contractor personnel shall submit all required information related to their background investigations (completion of the investigation documents (SF85, SF85P, or SF 86) utilizing the Office of Personnel Management's (OPM) Electronic Questionnaire for Investigations Processing (e-QIP) after receiving an email notification from the SIC.
- f. The Contractor employee shall certify and release the e-QIP document, print, and sign the signature pages, and send them encrypted to the COR for electronic submission to the SIC. These documents shall be submitted to the COR within 3 business days of receipt of the e-QIP notification email. (Note: OPM is moving towards a "click to sign" process. If click to sign is used, the Contractor employee should notify the COR within 3 business days that documents were signed via e-QIP).
- g. The Contractor shall be responsible for the actions of all personnel provided to work for VA under this contract. In the event that damages arise from work performed by Contractor provided personnel, under the auspices of this contract, the Contractor shall be responsible for all resources necessary to remedy the incident.
- h. A Contractor may be granted unescorted access to VA facilities and/or access to VA Information Technology resources (network and/or protected data) with a favorably adjudicated Special Agreement Check (SAC), completed training delineated in VA Handbook 6500.6 (Appendix C, Section

- 4), signed "Contractor Rules of Behavior", and with a valid, operational Personal Identity Verification (PIV) credential for PIV-only logical access to VA's network. A PIV card credential can be issued once your SAC has been favorably adjudicated and your background investigation has been scheduled by OPM. However, the Contractor will be responsible for the actions of the Contractor personnel they provide to perform work for VA. The investigative history for Contractor personnel working under this contract must be maintained in the database of OPM.
- i. The Contractor, when notified of an unfavorably adjudicated background investigation on a Contractor employee as determined by the Government, shall withdraw the employee from consideration in working under the contract.
 - j. Failure to comply with the Contractor personnel security investigative requirements may result in loss of physical and/or logical access to VA facilities and systems by Contractor and Subcontractor employees and/or termination of the contract for default.
 - k. PIV Credential Holders must follow all HSPD-12 policies and procedures as well as use and protect their assigned identity credentials in accordance with VA policies and procedures, displaying their badges at all times, and returning the identity credentials upon termination of their relationship with VA.

Deliverable:

- A. Contractor Staff Roster – Will be included in the CPMP

6.3 METHOD AND DISTRIBUTION OF DELIVERABLES

The Contractor shall deliver documentation in electronic format, unless otherwise directed in Section B of the solicitation/contract. Acceptable electronic media include: Microsoft 365 suite, MS Word, MS Excel, MS PowerPoint, MS Project, MS Access, MS Visio, AutoCAD, and Adobe Postscript Data Format (PDF).

6.4 PERFORMANCE METRICS

The table below defines the Performance Standards and Acceptable Levels of Performance associated with this effort.

Supply Chain GUI Overlay
VA-26-00023382

Performance Objective	Performance Standard	Acceptable Levels of Performance
A. Technical / Quality of Product or Service	1. Demonstrates understanding of requirements 2. Efficient and effective in meeting requirements 3. Meets technical needs and mission requirements 4. Provides quality services/products 5. Incorporates "ease of use" Human Centered Design principles in any software developed.	Satisfactory or higher
B. Project Milestones and Schedule	1. Established milestones and project dates are met 2. Products completed, reviewed, delivered in accordance with the established schedule 3. Notifies customer in advance of potential problems	Satisfactory or higher
C. Cost & Staffing	1. Currency of expertise and staffing levels appropriate to perform tasks required 2. Personnel possess necessary knowledge, skills, and abilities to perform tasks	Satisfactory or higher
D. Management	1. Integration and coordination of all activities to execute effort	Satisfactory or higher

The COR will utilize a Quality Assurance Surveillance Plan (QASP) throughout the life of the contract to ensure that the Contractor is performing the services required by this PWS in an acceptable level of performance. The Government reserves the right to alter or change the surveillance methods in the QASP at its own discretion. A Performance Based Service Assessment will be used by the COR in accordance with the QASP to assess Contractor performance.

6.5 FACILITY/RESOURCE PROVISIONS

Supply Chain GUI Overlay
VA-26-00023382

All procedural guides, reference materials, and program documentation for the project and other Government applications will also be provided on an as-needed basis.

The Contractor shall request other Government documentation deemed pertinent to the work accomplishment directly from the Government officials with whom the Contractor has contact. The Contractor shall consider the COR as the final source for needed Government documentation when the Contractor fails to secure the documents by other means. The Contractor is expected to use common knowledge and resourcefulness in securing all other reference materials, standard industry publications, and related materials that are pertinent to the work.

VA may provide remote access to VA specific systems/network in accordance with VA Handbook 6500, which requires the use of a VA approved method to connect external equipment/systems to VA's network. Citrix Access Gateway (CAG) and now the Azure Virtual Desktop (AVD) (as VA is currently transitioning from CAG to the AVD), are the current and only VA approved methods for remote access users when using or manipulating VA information for official VA Business. VA permits CAG remote access through approved Personally Owned Equipment (POE) and Other Equipment (OE) provided the equipment meets all applicable 6500 Handbook requirements for POE/OE. All of the security controls required for Government furnished equipment (GFE) must be utilized in approved POE or OE. The Contractor shall provide proof to the COR for review and approval that their POE or OE meets the VA Handbook 6500 requirements and VA Handbook 6500.6 Appendix C, herein incorporated as Addendum B, before use. CAG authorized users shall not be permitted to copy, print, or save any VA information accessed via CAG at any time. VA prohibits remote access to VA's network from non-North Atlantic Treaty Organization (NATO) countries. The exception to this are countries where VA has approved operations established (e.g. Philippines and South Korea). Exceptions are determined by the COR in coordination with the Information System Security Officer (ISSO) and Privacy Officer (PO).

This remote access may provide access to VA specific software such as Veterans Health Information System and Technology Architecture (VistA), ClearQuest, PAL, Primavera, and Remedy, including appropriate seat management and user licenses, depending upon the level of access granted. The Contractor shall utilize government-provided software development and test accounts, documents, and requirements repositories, etc. as required for the development, storage, maintenance, and delivery of products within the scope of this effort. All VA sensitive information shall be protected at all times in accordance with VA Handbook 6500, local security field office System Security Plans (SSP's) and Authority to Operate (ATO)'s for all systems/LAN's accessed while performing the tasks detailed in this PWS. The Contractor shall ensure all work is performed in countries deemed not to pose a significant security risk. For detailed Security and Privacy Requirements (additional requirements of the contract consolidated into an addendum for easy reference) refer to ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED and ADDENDUM B - VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE.

6.6 GOVERNMENT FURNISHED PROPERTY

The Government has multiple remote access solutions available to include CAG, AVD, Site-to-Site Virtual Private Network (VPN), and RESCUE VPN.

The Government's issuance of Government Furnished Equipment (GFE) is limited to Contractor personnel requiring direct access to the network to: development environments; install, configure and run Technical Reference Model (TRM) approved software and tools (e.g., KanBan/Jira, Oracle, Fortify, Eclipse, SoapUI, WebLogic, LoadRunner); upload/download/ manipulate code, run scripts, and apply patches; configure and change system settings; check logs, troubleshoot/debug, and test/QA.

When necessary, the Government will furnish desktops or laptops, for use by the Contractor to access VA networks, systems, or applications to meet the requirements of this PWS. The overarching goal is to determine the most cost-effective approach to providing needed access to the VA environment coupled with the need to ensure proper Change Management principles are followed. Contractor personnel shall adhere to all VA system access requirements for on-site and remote users in accordance with VA standards, local security regulations, policies, and rules of behavior. GFE shall be approved by the COR and Program Manager on a case-by-case basis prior to issuance.

Based upon the Government assessment of remote access solutions and requirements of this effort, the Government estimates that the following GFE will be required by this effort:

1. **30** laptops

The Government will not provide IT accessories including but not limited to Mobile Wi-Fi hotspots/wireless access points, additional or specialized keyboards or mice, laptop bags, extra charging cables, extra Personal Identity Verification card readers, peripheral devices, or additional Random Access Memory (RAM). The Contractor is responsible for providing these types of IT accessories in support of this effort as necessary and any VA installation required for these IT accessories shall be coordinated with the COR.

Additionally, the Contractor shall provide a status of all reportable GFE as part of the **Monthly** Status Report as required by PWS paragraph 5.1. For purposes of this report, reportable GFE includes equipment that is furnished by the Government as tangible "personal" property which the Contractor takes possession of, physically leaves a Government facility, and needs to be returned the end of Contractor performance. The following information shall be provided for each piece of GFE:

1. Name of Contractor employee assigned to the GFE
2. Type of Equipment (Make and Model)
3. Tracking Number/Serial Number
4. VA Bar Code
5. Location

6. Value
7. Total Value of Equipment
8. Anticipated Transfer Date to Government
9. Anticipated Transfer Location

DRAFT

ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED

A1.0 Cyber and Information Security Requirements for VA IT Services

The Contractor shall ensure adequate LAN/Internet, data, information, and system security in accordance with VA standard operating procedures and standard PWS language, conditions, laws, and regulations. The Contractor's firewall and web server shall meet or exceed VA minimum requirements for security. All VA data shall be protected behind an approved firewall. Any security violations or attempted violations shall be reported to the VA Program Manager and VA Information Security Officer as soon as possible. The Contractor shall follow all applicable VA policies and procedures governing information security, especially those that pertain to assessment and authorization and continuous monitoring.

Contractor supplied equipment, PCs of all types, equipment with hard drives, etc. for contract services must meet all security requirements that apply to Government Furnished Equipment (GFE) and Government Owned Equipment (GOE). Security Requirements include: a) VA Approved Encryption Software must be installed on all laptops or mobile devices before being placed into operation, b) Bluetooth equipped devices are prohibited within VA; Bluetooth must be permanently disabled or removed from the device, unless the connection uses FIPS 140-2 (or its successor) validated encryption, c) VA approved anti-virus and firewall software, d) Equipment must meet all VA sanitization requirements and procedures before disposal. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems.

Each documented initiative under this contract incorporates VA Handbook 6500.6, "Contract Security," March 12, 2010 (Appendix C updated April 22, 2024) by reference as though fully set forth therein. The VA Handbook 6500.6, "Contract Security" shall also be included in every related agreement, contract, or order. The VA Handbook 6500.6, Appendix C, is included in this document as Addendum B.

Training requirements: The Contractor shall complete all mandatory training courses on the current VA training site, the VA Talent Management System (TMS) 2.0, and will be tracked therein. The TMS 2.0 may be accessed at <https://www.tms.va.gov/SecureAuth35/>. If you do not have a TMS 2.0 profile, go to <https://www.tms.va.gov/SecureAuth35/> and click on the "Create New User" link on the TMS 2.0 to gain access.

Contractor employees shall complete a VA Systems Access Agreement if they are provided access privileges as an authorized user of the computer system of VA.

A2.0 VA Enterprise Architecture Compliance

The applications, supplies, and services furnished under this contract must comply with VA Enterprise Architecture (EA), available at <http://www.ea.oit.va.gov/index.asp> in force at the time of issuance of this contract, including the Program Management Plan and VA's rules, standards, and guidelines in the Technical Reference Model/Standards Profile (TRMSP). VA reserves the right to assess contract deliverables for EA compliance prior to acceptance.

A2.1. VA Internet and Intranet Standards

The Contractor shall adhere to and comply with VA Directive 6102 and VA's Web Governance if the Contractor's work includes building and maintaining VA's digital presence. This pertains, but is not limited to: websites, social media, creating announcements; collecting information; databases to be accessed, graphics and links to external sites.

Internet/Intranet Services Directive 6102 is posted at (copy and paste the following URL to browser): https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1056&FType=2

VA Web Governance website can be found at [Home - VA Web Governance](#).

A3.0 Notice of the Federal Accessibility Law Affecting All Information and Communication Technology (ICT) Procurements (Section 508)

On January 18, 2017, the Access Board issued a final rule that updated accessibility requirements covered by Section 508 and refreshed guidelines for telecommunications equipment subject to Section 255 of the Communications Act. The final rule went into effect on January 18, 2018. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

A3.1. Section 508 – Information and Communication Technology (ICT) Standards

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: [Revised 508 Standards and 255 Guidelines \(access-board.gov\)](#). A single PDF file version of the Revised Section 508 Standards and 255 Guidelines will be supplied upon request, or can be obtained from the Access Board website. Federal agencies must comply with the Rehabilitation Act of 1973, as amended.

The Contractor shall comply with "508 Chapter 2: Scoping Requirements" for all electronic ICT and content delivered under this contract. Specifically, as appropriate for

the technology and its functionality, the Contractor shall comply with the technical standards marked here:

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria
- ☒ E206 Hardware Requirements
- ☒ E207 Software Requirements
- ☒ E208 Support Documentation and Services Requirements

A3.2. Compatibility with Assistive Technology

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

A3.3. Acceptance and Acceptance Testing

Deliverables resulting from this solicitation will be accepted based in part on satisfaction of the Section 508 Chapter 2: Scoping Requirements standards identified above.

The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

A4.0 Physical Security & Safety Requirements:

The Contractor and their personnel shall follow all VA policies, standard operating procedures, applicable laws and regulations while on VA property. Violations of VA regulations and policies may result in citation and disciplinary measures for persons violating the law.

1. The Contractor and their personnel shall wear visible identification at all times while they are on the premises.
2. VA does not provide parking spaces at the work site; the Contractor must obtain parking at the work site if needed. It is the responsibility of the Contractor to park in the appropriate designated parking areas. VA will not invalidate or make reimbursement for parking violations of the Contractor under any conditions.
3. Smoking is prohibited inside/outside any building other than the designated smoking areas.
4. Possession of weapons is prohibited.

5. The Contractor shall obtain all necessary licenses and/or permits required to perform the work, with the exception of software licenses that need to be procured from a Contractor or vendor in accordance with the requirements document. The Contractor shall take all reasonable precautions necessary to protect persons and property from injury or damage during the performance of this contract.

A5.0 Confidentiality and Non-Disclosure

The Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations.

The Contractor may have access to Protected Health Information (PHI) and Electronic Protected Health Information (ePHI) that is subject to protection under the regulations issued by the Department of Health and Human Services, as mandated by the Health Insurance Portability and Accountability Act of 1996 (HIPAA); 45 CFR Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information ("Privacy Rule"); and 45 CFR Parts 160 and 164, Subparts A and C, the Security Standard ("Security Rule"). Pursuant to the Privacy and Security Rules, the Contractor must agree in writing to certain mandatory provisions regarding the use and disclosure of PHI and ePHI.

1. The Contractor will have access to some privileged and confidential materials of VA. These printed and electronic documents are for internal use only, are not to be copied or released without permission, and remain the sole property of VA. Some of these materials are protected by the Privacy Act of 1974 (revised by PL 93-5791) and Title 38. Unauthorized disclosure of Privacy Act or Title 38 covered materials is a criminal offense.
2. The VA CO will be the sole authorized official to release in writing, any data, draft deliverables, final deliverables, or any other written or printed materials pertaining to this contract. The Contractor shall release no information. Any request for information relating to this contract presented to the Contractor shall be submitted to the VA CO for response.
3. Contractor personnel recognize that in the performance of this effort, Contractor personnel may receive or have access to sensitive information, including information provided on a proprietary basis by carriers, equipment manufacturers and other private or public entities. Contractor personnel agree to safeguard such information and use the information exclusively in the performance of this contract. Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations as enumerated in this section and elsewhere in this Contract and its subparts and appendices.
4. Contractor shall limit access to the minimum number of personnel necessary for contract performance for all information considered sensitive or proprietary in nature. If the Contractor is uncertain of the sensitivity of any information obtained during the performance this contract, the Contractor has a responsibility to ask the VA CO.

5. Contractor shall train all of their employees involved in the performance of this contract on their roles and responsibilities for proper handling and nondisclosure of sensitive VA or proprietary information. Contractor personnel shall not engage in any other action, venture or employment wherein sensitive information shall be used for the profit of any party other than those furnishing the information. The sensitive information transferred, generated, transmitted, or stored herein is for VA benefit and ownership alone.
6. Contractor shall maintain physical security at all facilities housing the activities performed under this contract, including any Contractor facilities according to VA-approved guidelines and directives. The Contractor shall ensure that security procedures are defined and enforced to ensure all personnel who are provided access to patient data must comply with published procedures to protect the privacy and confidentiality of such information as required by VA.
7. Contractor must adhere to the following:
 - a. The use of "thumb drives" or any other medium for transport of information is expressly prohibited.
 - b. Controlled access to system and security software and documentation.
 - c. Recording, monitoring, and control of passwords and privileges.
 - d. All terminated personnel are denied physical and electronic access to all data, program listings, data processing equipment and systems.
 - e. VA, as well as any Contractor (or Subcontractor) systems used to support development, provide the capability to cancel immediately all access privileges and authorizations upon employee termination.
 - f. Contractor PM and VA PM are informed within twenty-four (24) hours of any employee termination.
 - g. Acquisition sensitive information shall be marked "Acquisition Sensitive" and shall be handled as "For Official Use Only (FOUO)".
 - h. Contractor does not require access to classified data.
8. Regulatory standard of conduct governs all personnel directly and indirectly involved in procurements. All personnel engaged in procurement and related activities shall conduct business in a manner above reproach and, except as authorized by statute or regulation, with complete impartiality and with preferential treatment for none. The general rule is to strictly avoid any conflict of interest or even the appearance of a conflict of interest in VA/Contractor relationships.
9. VA Form 0752 shall be completed by all Contractor employees working on this contract and shall be provided to the CO before any work is performed. In the case that Contractor personnel are replaced in the future, their replacements shall complete VA Form 0752 prior to beginning work.

A6.0 Information Technology Using Sustainable Products and Services

Not Applicable

DRAFT

ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/ PRIVACY LANGUAGE

NOTE: In the event of a conflict, VAAR Security Clauses take precedence over the language in this Addendum B.

APPLICABLE SECTIONS FROM: *VA NOTICE 24-12, APRIL 22, 2024, UPDATE TO VA HANDBOOK 6500.6, CONTRACT SECURITY, APPENDIX C VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE, FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE*

B1. GENERAL

This entire section applies to all acquisitions requiring any Information Security and Privacy language. Contractors, contractor personnel, Subcontractors and subcontractor personnel will be subject to the same federal laws, regulations, standards, VA directives and handbooks, as VA personnel regarding information and information system security and privacy.

B2. VA INFORMATION CUSTODIAL LANGUAGE

a. A Contractor/Subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees, Subcontractors, and affiliates only to the extent necessary to perform the services specified in the contract, agreement, or task order.

b. All Contractors, Subcontractors, and third-party servicers and associates working with VA information are subject to the same investigative requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for Contractors must be in accordance with VA Directive and Handbook 0710, *Personnel Suitability and Security Program*. The Office for Operations, Security, and Preparedness is responsible for these policies and procedures.

c. Contract personnel who require access to national security programs must have a valid security clearance. National Industrial Security Program (NISP) was established by Executive Order 12829 to ensure that cleared U.S. defense industry contract personnel safeguard the classified information in their possession while performing work on contracts, programs, bids, or research and development efforts. The Department of Veterans Affairs does not have a Memorandum of Agreement with Defense Security Service (DSS). Verification of a Security Clearance must be processed through the Special Security Officer located in the Planning and National Security Service within the Office of Operations, Security, and Preparedness.

Supply Chain GUI Overlay
VA-26-00023382

d. Custom software development and outsourced operations must be located in the U.S. to the maximum extent practical. If such services are proposed to be performed abroad and are not disallowed by other VA policy or mandates (e.g. Business Associate Agreement, Section 3G), the Contractor/Subcontractor must state where all non-U.S. services are provided and detail a security plan, deemed to be acceptable by VA, specifically to address mitigation of the resulting problems of communication, control, data protection, and so forth. Location within the U.S. may be an evaluation factor.

e. The Contractor or Subcontractor must notify the CO immediately when an employee working on a VA system or with access to VA information is reassigned or leaves the Contractor or Subcontractor's employ. The CO must also be notified immediately by the Contractor or Subcontractor prior to an unfriendly termination.

- a. Information made available to the Contractor by VA for the performance or administration of this contract will be used only for the purposes specified in the service agreement, SOW, PWS, PD, and/or contract. The Contractor shall not use VA information in any other manner without prior written approval from a VA Contracting Officer (CO). The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General.
- b. VA information will not be co-mingled with any other data on the Contractor's information systems or media storage systems. The Contractor shall ensure compliance with Federal and VA requirements related to data protection, data encryption, physical data segregation, logical data segregation, classification requirements and media sanitization.
- c. VA reserves the right to conduct scheduled or unscheduled audits, assessments, or investigations of Contractor Information Technology (IT) resources to ensure information security is compliant with Federal and VA requirements. The Contractor shall provide all necessary access to records (including electronic and documentary materials related to the contracts and subcontracts) and support (including access to Contractor and Subcontractor staff associated with the contract) to VA, VA's Office Inspector General (OIG), and/or Government Accountability Office (GAO) staff during periodic control assessments, audits, or investigations.
- d. The Contractor may only use VA information within the terms of the contract and applicable Federal law, regulations, and VA policies. If new Federal information security laws, regulations or VA policies become applicable after execution of the contract, the parties agree to negotiate contract modification and adjustment necessary to implement the new laws, regulations, and/or policies.
- e. The Contractor shall not make copies of VA information except as specifically authorized and necessary to perform the terms of the contract. If copies are made for restoration purposes, after the restoration is complete, the copies shall

Supply Chain GUI Overlay
VA-26-00023382

be destroyed in accordance with VA Directive 6500, VA Cybersecurity Program and VA Information Security Knowledge Service.

- f. If a Veterans Health Administration (VHA) contract is terminated for default or cause with a business associate, the related local Business Associate Agreement (BAA) shall also be terminated and actions taken in accordance with VHA Directive 1605.05, Business Associate Agreements. If there is an executed national BAA associated with the contract, VA will determine what actions are appropriate and notify the contractor.
- g. The Contractor shall store and transmit VA sensitive information in an encrypted form, using VA-approved encryption tools which are, at a minimum, Federal Information Processing Standards (FIPS) 140-2, Security Requirements for Cryptographic Modules (or its successor) validated and in conformance with VA Information Security Knowledge Service requirements. The Contractor shall transmit VA sensitive information using VA approved Transport Layer Security (TLS) configured with FIPS based cipher suites in conformance with National Institute of Standards and Technology (NIST) 800-52, Guidelines for the Selection, Configuration and Use of Transport Layer Security (TLS) Implementations.
- h. The Contractor's firewall and web services security controls, as applicable, shall meet or exceed VA's minimum requirements.
- i. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the Contractor may use and disclose VA information only in two situations: (i) in response to a qualifying order of a court of competent jurisdiction after notification to VA CO (ii) with written approval from the VA CO. The Contractor shall refer all requests for, demands for production of or inquiries about, VA information and information systems to the VA CO for response.
- j. Notwithstanding the provision above, the Contractor shall not release VA records protected by Title 38 U.S.C. § 5705, Confidentiality of medical quality-assurance records and/or Title 38 U.S.C. § 7332, Confidentiality of certain medical records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse or infection with Human Immunodeficiency Virus (HIV). If the Contractor is in receipt of a court order or other requests for the above-mentioned information, the Contractor shall immediately refer such court order or other requests to the VA CO for response.
- k. Information made available to the Contractor by VA for the performance or administration of this contract or information developed by the Contractor in performance or administration of the contract will be protected and secured in accordance with VA Directive 6500 and Identity and Access Management (IAM) Security processes specified in the VA Information Security Knowledge Service.

Supply Chain GUI Overlay
VA-26-00023382

- l. Any data destruction done on behalf of VA by a Contractor shall be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, Records and Information Management, VA Handbook 6300.1, Records Management Procedures, and applicable VA Records Control Schedules.
- m. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Directive 6500 and NIST 800-88, Guidelines for Media Sanitization prior to termination or completion of this contract. If directed by the COR/CO, the Contractor shall return all Federal Records to VA for disposition.
- n. Any media, such as paper, magnetic tape, magnetic disks, solid state devices or optical discs that is used to store, process, or access VA information that cannot be destroyed shall be returned to VA. The Contractor shall hold the appropriate material until otherwise directed by the Contracting Officer's Representative (COR) or CO. Items shall be returned securely via VA-approved methods. VA sensitive information must be transmitted utilizing VA-approved encryption tools which are validated under FIPS 140-2 (or its successor) and NIST 800-52. If mailed, the Contractor shall send via a trackable method (USPS, UPS, FedEx, etc.) and immediately provide the COR/CO with the tracking information. Self-certification by the Contractor that the data destruction requirements above have been met shall be sent to the COR/CO within 30 business days of termination of the contract.
- o. All electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) used to store, process or access VA information will not be returned to the Contractor at the end of lease, loan, or trade-in. Exceptions to this paragraph will only be granted with the written approval of the VA CO.

B3. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

- a. A Contractor/Subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees and subcontractors only to the extent necessary to perform the services specified in the solicitation or contract. This includes indirect entities, both affiliate of Contractor/Subcontractor and agent of Contractor/Subcontractor.
- b. Contractors and subcontractors shall sign the VA Information Security Rule of Behavior (ROB) before access is provided to VA information and information systems (see Section 4, Training, below). The ROB contains the minimum user compliance requirements and does not supersede any policies of VA facilities or other agency components which provide higher levels of protection to VA's information or information systems. Users who require privileged access shall complete the VA elevated privilege access request processes before privileged access is granted.

- c. All Contractors and Subcontractors working with VA information are subject to the same security investigative and clearance requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for contractors shall be in accordance with VA Directive and Handbook 0710, Personnel Suitability and Security Program. The Office of Human Resources and Administration/Operations, Security and Preparedness (HRA/OSP) is responsible for these policies and procedures. Contract personnel who require access to classified information or information systems shall have an appropriate security clearance. Verification of a Security Clearance shall be processed through the Special Security Officer located in HRA/OSP. Contractors shall conform to all requirements stated in the National Industrial Security Program Operating Manual (NISPOM).
- d. All Contractors and subcontractors shall comply with conditions specified in VAAR 852.204-71(d); Contractor operations required to be in United States. All Contractors and Subcontractors working with VA information must be permanently located within a jurisdiction subject to the law of the United States or its Territories to the maximum extent feasible. If services are proposed to be performed abroad the Contractor must state where all non-U.S. services are provided. The Contractor shall deliver to VA a detailed plan specifically addressing communications, personnel control, data protection and potential legal issues. The plan shall be approved by the COR/CO in writing prior to access being granted.
- e. The Contractor shall notify the COR/CO in writing immediately (no later than 24 hours) after personnel separation or occurrence of other causes. Causes may include the following:
 - (1) Contractor/Subcontractor personnel no longer has a need for access to VA information or VA information systems.
 - (2) Contractor/Subcontractor personnel are terminated, suspended, or otherwise has their work on a VA project discontinued for any reason.
 - (3) Contractor believes their own personnel or Subcontractor personnel may pose a threat to their company's working environment or to any company-owned property. This includes Contractor-owned assets, buildings, confidential data, customers, employees, networks, systems, trade secrets and/or VA data.
 - (4) Any previously undisclosed changes to Contractor/Subcontractor background history are brought to light, including but not limited to changes to background investigation or employee record.

Supply Chain GUI Overlay
VA-26-00023382

- (5) Contractor/Subcontractor personnel have their authorization to work in the United States revoked.
- (6) Agreement by which Contractor provides products and services to VA has either been fulfilled or terminated, such that VA can cut off electronic and/or physical access for Contractor personnel.
- f. In such cases of contract fulfillment, termination, or other causes; the Contractor shall take the necessary measures to immediately revoke access to VA network, property, information, and information systems (logical and physical) by Contractor/Subcontractor personnel. These measures include (but are not limited to): removing and then securing Personal Identity Verification (PIV) badges and PIV – Interoperable (PIV-I) access badges, VA-issued photo badges, credentials for VA facilities and devices, VA-issued laptops, and authentication tokens. Contractors shall notify the appropriate VA COR/CO immediately to initiate access removal.
- g. Contractors/Subcontractors who no longer require VA accesses will return VA-issued property to VA. This property includes (but is not limited to): documents, electronic equipment, keys, and parking passes. PIV and PIV-I access badges shall be returned to the nearest VA PIV Badge Issuance Office. Once they have had access to VA information, information systems, networks and VA property in their possessions removed, Contractors shall notify the appropriate VA COR/CO.

B4. TRAINING

- a. All contractors and subcontractors requiring access to VA information and VA information systems shall successfully complete the following before being granted access to VA information and its systems:
 - (1) VA Privacy and Information Security Awareness and Rules of Behavior course (Talent Management System (TMS) #10176) initially and annually thereafter.
 - (2) Sign and acknowledge (electronically through TMS #10176) understanding of and responsibilities for compliance with the Organizational Rules of Behavior, relating to access to VA information and information systems initially and annually thereafter; and
 - (3) Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system or information access [to be defined by the VA program official and provided to the VA CO for inclusion in the solicitation document – i.e., any role-based information security training].

- b. The Contractor shall provide to the COR/CO a copy of the training certificates and certification of signing the Organizational Rules of Behavior for each applicable employee within five days of the initiation of the contract and annually thereafter, as required.
- c. Failure to complete the mandatory annual training is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the required training is complete.

B5. SECURITY INCIDENT INVESTIGATION

- a. The Contractor, Subcontractor, their employees, or business associates shall immediately (within one hour) report suspected security / privacy incidents to the VA OIT's Enterprise Service Desk (ESD) by calling (855) 673-4357 (TTY: 711). The ESD is OIT's 24/7/365 single point of contact for IT-related issues. After reporting to the ESD, the Contractor, Subcontractor, their employees, or business associates shall, within one hour, provide the COR/CO the incident number received from the ESD.
- b. To the extent known by the Contractor/Subcontractor, the Contractor/Subcontractor's notice to VA shall identify the information involved and the circumstances surrounding the incident, including the following:
 - (1) The date and time (or approximation of) the Security Incident occurred.
 - (2) The names of individuals involved (when applicable).
 - (3) The physical and logical (if applicable) location of the incident.
 - (4) Why the Security Incident took place (i.e., catalyst for the failure).
 - (5) The amount of data belonging to VA believed to have been compromised.
 - (6) The remediation measures the Contractor is taking to ensure no future incidents of a similar nature.
- c. After the Contractor has provided the initial detailed incident summary to VA, they will continue to provide written updates on any new and relevant circumstances or facts they discover. The Contractor, Subcontractor, and their employees shall fully cooperate with VA or third-party entity performing an independent risk analysis on behalf of VA. Failure to cooperate may be deemed a material breach and grounds for contract termination.
- d. VA IT Contractors shall follow VA Handbook 6500, Risk Management Framework for VA Information Systems VA Information Security Program, and VA

Information Security Knowledge Service guidance for implementing an Incident Response Plan or integrating with an existing VA implementation.

- e. In instances of theft or break-in or other criminal activity, the Contractor/Subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG, and the VA Office of Security and Law Enforcement. The Contractor, its employees, and its Subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/Subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.
- f. The Contractor shall comply with VA Handbook 6500.2, Management of Breaches Involving Sensitive Personal Information, which establishes the breach management policies and assigns responsibilities for the oversight, management and reporting procedures associated with managing of breaches.
- g. With respect to unsecured Protected Health Information (PHI), the Contractor is deemed to have discovered a data breach when the Contractor knew or should have known of breach of such information. When a business associate is part of VHA contract, notification to the covered entity (VHA) shall be made in accordance with the executed BAA.
- h. If the Contractor or any of its agents fails to protect VA sensitive personal information or otherwise engages in conduct which results in a data breach involving any VA sensitive personal information the Contractor/Subcontractor processes or maintains under the contract; the Contractor shall pay liquidated damages to the VA as set forth in clause [852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs](#).

B6. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

- a. Information systems designed or developed on behalf of VA at non-VA facilities shall comply with all applicable Federal law, regulations, and VA policies. This includes standards for the protection of electronic Protected Health Information (PHI), outlined in 45 C.F.R. Part 164, Subpart C and information and system security categorization level designations in accordance with FIPS 199, Standards for Security Categorization of Federal Information and Information Systems and FIPS 200, Minimum Security Requirements for Federal Information Systems. Baseline security controls shall be implemented commensurate with the FIPS 199 system security categorization (reference VA Handbook 6500 and VA Trusted Internet Connections (TIC) Architecture).

Supply Chain GUI Overlay
VA-26-00023382

- b. Contracted new developments require creation, testing, evaluation, and authorization in compliance with VA Assessment and Authorization (A&A) processes in VA Handbook 6500 and VA Information Security Knowledge Service to obtain an Authority to Operate (ATO). VA Directive 6517, Risk Management Framework for Cloud Computing Services, provides the security and privacy requirements for cloud environments.
- c. VA IT Contractors, Subcontractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500, VA Handbook 6517, Risk Management Framework for Cloud Computing Services and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO to identify the VA organization responsible for governance or resolution. Contractors shall comply with FAR 39.1, specifically the prohibitions referenced.
- d. The Contractor (including producers and resellers) shall comply with Office of Management and Budget (OMB) M-22-18 and M-23-16 when using third-party software on VA information systems or otherwise affecting the VA information. This includes new software purchases and software renewals for software developed or modified by major version change after the issuance date of M-22-18 (September 14, 2022). The term "software" includes firmware, operating systems, applications and application services (e.g., cloud-based software), as well as products containing software. The Contractor shall provide a self-attestation that secure software development practices are utilized as outlined by Executive Order (EO) 14028 and NIST Guidance. A third-party assessment provided by either a certified Federal Risk and Authorization Management Program (FedRAMP) Third Party Assessor Organization (3PAO) or one approved by the agency will be acceptable in lieu of a software producer's self-attestation.
- e. The Contractor shall ensure all delivered applications, systems and information systems are compliant with Homeland Security Presidential Directive (HSPD) 12 and VA Identity and Access management (IAM) enterprise identity management requirements as set forth in OMB M-19-17, M-05-24, FIPS 201-3, Personal Identity Verification (PIV) of Federal Employees and Contractors (or its successor), M-21-31 and supporting NIST guidance. This applies to Commercial Off-The-Shelf (COTS) product(s) that the Contractor did not develop, all software configurations and all customizations.
- f. The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with VA Handbook 6500, VA Information Security Knowledge Service, IAM enterprise requirements and NIST 800-63, Digital Identity Guidelines, for direct, assertion-based authentication and/or trust-based authentication, as determined by the design and integration patterns. Direct authentication at a minimum must include Public Key

Supply Chain GUI Overlay
VA-26-00023382

Infrastructure (PKI) based authentication supportive of PIV and/or Common Access Card (CAC), as determined by the business need and compliance with VA Information Security Knowledge Service specifications.

- g. The Contractor shall use VA authorized technical security baseline configurations and certify to the COR that applications are fully functional and operate correctly as intended on systems in compliance with VA baselines prior to acceptance or connection into an authorized VA computing environment. If the Defense Information Systems Agency (DISA) has created a Security Technical Implementation Guide (STIG) for the technology, the Contractor may configure to comply with that STIG. If VA determines a new or updated VA configuration baseline needs to be created, the Contractor shall provide required technical support to develop the configuration settings. FAR 39.1 requires the population of operating systems and applications includes all listed on the NIST National Checklist Program Checklist Repository,
- h. The standard installation, operation, maintenance, updating and patching of software shall not alter the configuration settings from VA approved baseline configuration. Software developed for VA must be compatible with VA enterprise installer services and install to the default "program files" directory with silently install and uninstall. The Contractor shall perform testing of all updates and patching prior to implementation on VA systems.
- i. Applications designed for normal end users will run in the standard user context without elevated system administration privileges.
- j. The Contractor-delivered solutions shall reside on VA approved operating systems. Exceptions to this will only be granted with the written approval of the COR/CO.
- k. The Contractor shall design, develop, and implement security and privacy controls in accordance with the provisions of VA security system development life cycle outlined in NIST 800-37, Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy, VA Directive and Handbook 6500, and VA Handbook 6517.
- l. The Contractor shall comply with the Privacy Act of 1974 (the Act), FAR 52.224-2 Privacy Act, and VA rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish a VA function.
- m. The Contractor shall ensure the security of all procured or developed information systems, systems, major applications, minor applications, enclaves and platform information technologies, including their subcomponents (hereinafter referred to as "Information Systems") throughout the life of this contract and any extension, warranty, or maintenance periods. This includes security configurations,

workarounds, patches, hotfixes, upgrades, replacements and any physical components which may be necessary to remediate all security vulnerabilities published or known to the Contractor anywhere in the information systems (including systems, operating systems, products, hardware, software, applications and firmware). The Contractor shall ensure security fixes do not negatively impact the Information Systems.

- n. When the Contractor is responsible for operations or maintenance of the systems, the Contractor shall apply the security fixes within the timeframe specified by the associated controls on the VA Information Security Knowledge Service. When security fixes involve installing third party patches (such as Microsoft OS patches or Adobe Acrobat), the Contractor shall provide written notice to the VA COR/CO that the patch has been validated as to not affecting the Systems within 10 business days.

B7. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE OR USE

- a. The Contractor shall comply with all Federal laws, regulations, and VA policies for Information systems (cloud and non-cloud) that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities. Security controls for collecting, processing, transmitting, and storing of VA sensitive information, must be in place. The controls will be tested by VA or a VA sanctioned 3PAO and approved by VA prior to hosting, operation, maintenance or use of the information system or systems by or on behalf of VA. This includes conducting compliance risk assessments, security architecture analysis, routine vulnerability scanning, system patching, change management procedures and the completion of an acceptable contingency plan for each system. The Contractor's security control procedures shall be the same as procedures used to secure VA-operated information systems.
- b. Outsourcing (Contractor facility, equipment, or staff) of systems or network operations, telecommunications services or other managed services require Assessment and Authorization (A&A) of the Contractor's systems in accordance with VA Handbook 6500 as specified in VA Information Security Knowledge Service. Major changes to the A&A package may require reviewing and updating all the documentation associated with the change. The Contractor's cloud computing systems shall comply with FedRAMP and VA Directive 6517 requirements.
- c. The Contractor shall return all electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) on non-VA leased or non-VA owned IT equipment used to store, process or access VA information to VA in accordance with A&A package requirements. This applies when the contract is terminated or completed and prior to disposal of media. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Information Security Knowledge Service requirements and NIST 800-88. The Contractor

Supply Chain GUI Overlay
VA-26-00023382

shall send a self-certification that the data destruction requirements above have been met to the COR/CO within 30 business days of termination of the contract.

- d. All external internet connections to VA network involving VA information must be in accordance with VA Trusted Internet Connection (TIC) Reference Architecture and VA Directive and Handbook 6513, Secure External Connections and reviewed and approved by VA prior to implementation. Government-owned Contractor-operated systems, third party or business partner networks require a Memorandum of Understanding (MOU) and Interconnection Security Agreements (ISA).
- e. Contractor procedures shall be subject to periodic, announced, or unannounced assessments by VA officials, the OIG or a 3PAO. The physical security aspects associated with Contractor activities are also subject to such assessments. The Contractor shall report, in writing, any deficiencies noted during the above assessment to the VA COR/CO. The Contractor shall use VA's defined processes to document planned remedial actions that address identified deficiencies in information security policies, procedures, and practices. The Contractor shall correct security deficiencies within the timeframes specified in the VA Information Security Knowledge Service.
- f. All major information system changes which occur in the production environment shall be reviewed by the VA to determine the impact on privacy and security of the system. Based on the review results, updates to the Authority to Operate (ATO) documentation and parameters may be required to remain in compliance with VA Handbook 6500 and VA Information Security Knowledge Service requirements.
- g. The Contractor shall conduct an annual privacy and security self-assessment on all information systems and outsourced services as required. Copies of the assessment shall be provided to the COR/CO. The VA/Government reserves the right to conduct assessment using government personnel or a third-party if deemed necessary. The Contractor shall correct or mitigate any weaknesses discovered during the assessment.
- h. VA prohibits the installation and use of personally owned or Contractor-owned equipment or software on VA information systems. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, PWS, PD or contract. All security controls required for government furnished equipment must be utilized in VA approved Other Equipment (OE). Configuration changes to the Contractor OE must be funded by the owner of the equipment. All remote systems must use a VA-approved antivirus software and a personal (host-based or enclave based) firewall with a VA-approved configuration. The Contractor shall ensure software on OE is kept current with all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-virus software and the firewall

on the non-VA owned OE. Approved Contractor OE will be subject to technical inspection at any time.

- i. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems. The system or effected component(s) need(s) to be isolated from the network. A forensic analysis needs to be conducted jointly with VA. Such issues will be remediated as quickly as practicable, but in no event longer than the timeframe specified by VA Information Security Knowledge Service. If sensitive personal information is compromised reference VA Handbook 6500.2 and Section 5, Security Incident Investigation.
- j. For cases wherein the Contractor discovers material defects or vulnerabilities impacting products and services they provide to VA, the Contractor shall develop and implement policies and procedures for disclosure to VA, as well as remediation. The Contractor shall, within 30 business days of discovery, document a summary of these vulnerabilities or defects. The documentation will include a description of the potential impact of each vulnerability and material defect, compensating security controls, mitigations, recommended corrective actions, root cause analysis and/or workarounds (i.e., monitoring). Should there exist any backdoors in the products or services they provide to VA (referring to methods for bypassing computer authentication), the Contractor shall provide the VA CO/CO written assurance they have permanently remediated these backdoors.
- k. All other vulnerabilities, including those discovered through routine scans or other assessments, will be remediated based on risk, in accordance with the remediation timelines specified by the VA Information Security Knowledge Service and/or the applicable timeframe mandated by Cybersecurity & Infrastructure Security Agency (CISA) Binding Operational Directive (BOD) 22-01 and BOD 19-02 for Internet-accessible systems. Exceptions to this paragraph will only be granted with the approval of the COR/CO.

B8. SECURITY AND PRIVACY CONTROLS COMPLIANCE TESTING, ASSESSMENT AND AUDITING

- a. Should VA request it, the Contractor shall provide a copy of their (corporation's, sole proprietorship's, partnership's, limited liability company (LLC), or other business structure entity's) policies, procedures, evidence and independent report summaries related to specified cybersecurity frameworks (International Organization for Standardization (ISO), NIST Cybersecurity Framework (CSF), etc.). VA or its third-party/partner designee (if applicable) are further entitled to perform their own audits and security/penetration tests of the Contractor's IT or systems and controls, to ascertain whether the Contractor is complying with the

information security, network or system requirements mandated in the agreement between VA and the Contractor.

- b. Any audits or tests of the Contractor or third-party designees/partner VA elects to carry out will commence within 30 business days of VA notification. Such audits, tests and assessments may include the following: (a): security/penetration tests which both sides agree will not unduly impact Contractor operations; (b): interviews with pertinent stakeholders and practitioners; (c): document review; and (d): technical inspections of networks and systems the Contractor uses to destroy, maintain, receive, retain, or use VA information.
- c. As part of these audits, tests and assessments, the Contractor shall provide all information requested by VA. This information includes, but is not limited to, the following: equipment lists, network or infrastructure diagrams, relevant policy documents, system logs or details on information systems accessing, transporting, or processing VA data.
- d. The Contractor and at its own expense, shall comply with any recommendations resulting from VA audits, inspections and tests. VA further retains the right to view any related security reports the Contractor has generated as part of its own security assessment. The Contractor shall also notify VA of the existence of any such security reports or other related assessments, upon completion and validation.
- e. VA appointed auditors or other government agency partners may be granted access to such documentation on a need-to-know basis and coordinated through the COR/CO. The Contractor shall comply with recommendations which result from these regulatory assessments on the part of VA regulators and associated government agency partners.

B9. PRODUCT INTEGRITY, AUTHENTICITY, PROVENANCE, ANTI-COUNTERFEIT AND ANTI-TAMPERING

- a. The Contractor shall comply with Code of Federal Regulations (CFR) Title 15 Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain", which prohibits ICTS Transactions from foreign adversaries. ICTS Transactions are defined as any acquisition, importation, transfer, installation, dealing in or use of any information and communications technology or service, including ongoing activities, such as managed services, data transmission, software updates, repairs or the platforming or data hosting of applications for consumer download.
- b. When contracting terms require the Contractor to procure equipment, the Contractor shall purchase or acquire the equipment from an Original Equipment Manufacturer (OEM) or an authorized reseller of the OEM. The Contractor shall attest that equipment procured from an OEM or authorized reseller or distributor

are authentic. If procurement is unavailable from an OEM or authorized reseller, the Contractor shall submit in writing, details of the circumstances prohibiting this from happening and procure a product waiver from the VA COR/CO.

- c. All Contractors shall establish, implement, and provide documentation for risk management practices for supply chain delivery of hardware, software (to include patches) and firmware provided under this agreement. Documentation will include chain of custody practices, inventory management program, information protection practices, integrity management program for sub-supplier provided components, and replacement parts requests. The Contractor shall make spare parts available. All Contractor(s) shall specify how digital delivery for procured products, including patches, will be validated and monitored to ensure consistent delivery. The Contractor shall apply encryption technology to protect procured products throughout the delivery process.
- d. If a Contractor provides software or patches to VA, the Contractor shall publish or provide a hash conforming to the FIPS Security Requirements for Cryptographic Modules (FIPS 140-2 or successor).
- e. The Contractor shall provide a software bill of materials (SBOM) for procured (to include licensed products) and consist of a list of components and associated metadata which make up the product. SBOMs must be generated in one of the data formats defined in the National Telecommunications and Information Administration (NTIA) report "The Minimum Elements for a Software Bill of Materials (SBOM)."
- f. Contractors shall use or arrange for the use of trusted channels to ship procured products, such as U.S. registered mail and/or tamper-evident packaging for physical deliveries.
- g. Throughout the delivery process, the Contractor shall demonstrate a capability for detecting unauthorized access (tampering).
- h. The Contractor shall demonstrate chain-of-custody documentation for procured products and require tamper-evident packaging for the delivery of this hardware.

B10. VIRUSES, FIRMWARE, AND MALWARE

- a. The Contractor shall execute due diligence to ensure all provided software and patches, including third-party patches, are free of viruses and/or malware before releasing them to or installing them on VA information systems.
- b. The Contractor warrants it has no knowledge of and did not insert, any malicious virus and/or malware code into any software or patches provided to VA which could potentially harm or disrupt VA information systems. The Contractor shall use due diligence, if supplying third-party software or patches, to ensure the

third-party has not inserted any malicious code and/or virus which could damage or disrupt VA information systems.

- c. The Contractor shall provide or arrange for the provision of technical justification as to why any “false positive” hit has taken place to ensure their code’s supply chain has not been compromised. Justification may be required, but is not limited to, when install files, scripts, firmware, or other Contractor-delivered software solutions (including third-party install files, scripts, firmware, or other software) are flagged as malicious, infected, or suspicious by an anti-virus vendor.
- d. The Contractor shall not upload (intentionally or negligently) any virus, worm, malware or any harmful or malicious content, component and/or corrupted data/source code (hereinafter “virus or other malware”) onto VA computer and information systems and/or networks. If introduced (and this clause is violated), upon written request from the VA CO, the Contractor shall:
 - (1) Take all necessary action to correct the incident, to include any and all assistance to VA to eliminate the virus or other malware throughout VA’s information networks, computer systems and information systems; and
 - (2) Use commercially reasonable efforts to restore operational efficiency and remediate damages due to data loss or data integrity damage, if the virus or other malware causes a loss of operational efficiency, data loss, or damage to data integrity.

B11. CRYPTOGRAPHIC REQUIREMENT

- a. The Contractor shall document how the cryptographic system supporting the Contractor’s products and/or services protect the confidentiality, data integrity, authentication and non-repudiation of devices and data flows in the underlying system.
- b. The Contractor shall use only approved cryptographic methods as defined in FIPS 140-2 (or its successor) and NIST 800-52 standards when enabling encryption on its products.
- c. The Contractor shall provide or arrange for the provision of an automated remote key-establishment method which protects the confidentiality and integrity of the cryptographic keys.
- d. The Contractor shall ensure emergency re-keying of all devices can be remotely performed within 30 business days.
- e. The Contractor shall provide or arrange for the provision of a method for updating cryptographic primitives or algorithms.

B12. PATCHING GOVERNANCE

- a. The Contractor shall provide documentation detailing the patch management, vulnerability management, mitigation and update processes (to include third-party) prior to the connection of electronic devices, assets or equipment to VA's assets. This documentation will include information regarding the following:
 - (1) The resources and technical capabilities to sustain the program or process (e.g., how the integrity of a patch is validated by VA); and.
 - (2) The approach and capability to remediate newly reported zero-day vulnerabilities for Contractor products.
- b. The Contractor shall verify and provide documentation all procured products (including third-party applications, hardware, software, operating systems, and firmware) have appropriate updates and patches installed prior to delivery to VA.
- c. The Contractor shall provide or arrange the provision of appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses for their products and services within 30 days of discovery. Updates to remediate critical or emergent vulnerabilities will be provided within seven business days of discovery. If updates cannot be made available by Contractor within these time periods, the Contractor shall submit mitigations, methods of exploit detection and/or workarounds to the COR/CO prior to the above deadlines.
- d. The Contractor shall provide or arrange for the provision of appropriate hardware, software and/or firmware updates, when those products, including open-source software, are provided to the VA, to remediate newly discovered vulnerabilities or weaknesses. Remediations of products or services provided to the VA's system environment must be provided within 30 business days of availability from the original supplier and/or patching source. Updates to remediate critical vulnerabilities applicable to the Contractor's use of the third-party product in its system environment will be provided within seven business days of availability from the original supplier and/or patching source. If applicable third-party updates cannot be integrated, tested and made available by Contractor within these time periods, mitigations and/or workarounds will be provided to the COR/CO before the above deadlines.

B13. SPECIALIZED DEVICES/SYSTEMS (MEDICAL DEVICES, SPECIAL PURPOSE SYSTEMS, RESEARCH SCIENTIFIC COMPUTING)

- a. Contractor supplies/delivered Medical Devices, Special Purpose Systems-Operational Technology (SPS-OT) and Research Scientific Computing Devices shall comply with all applicable Federal law, regulations, and VA policies. New developments require creation, testing, evaluation, and authorization in compliance with processes specified on the Specialized Device Cybersecurity

Supply Chain GUI Overlay
VA-26-00023382

Department Enterprise Risk Management (SDCD-ERM) Portal, VA Directive 6550, Pre-Procurement Assessment and Implementation of Medical Devices/Systems, VA Handbook 6500, and the VA Information Security Knowledge Service. Deviations from Federal law, regulations, and VA Policy are identified and documented as part of VA Directive 6550 and/or the VA Enterprise Risk Analysis (ERA) processes for Specialized Devices/Systems processes.

- b. All Contractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500 and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO for governance or resolution.
- c. The Contractor shall certify to the COR/CO that devices/systems that have completed the VA Enterprise Risk Analysis (ERA) process for Specialized Devices/Systems are fully functional and operate correctly as intended. Devices/systems must follow the VA ERA authorized configuration prior to acquisition and connection to the VA computing environment. If VA determines a new VA ERA needs to be created, the Contractor shall provide required technical support to develop the configuration settings. Major changes to a previously approved device/system will require a new ERA.
- d. The Contractor shall comply with all practices documented by the Food Drug and Administration (FDA) Premarket Submission for Management of Cybersecurity in Medical Devices and Postmarket Management of Cybersecurity in Medical Devices.
- e. The Contractor shall design devices capable of accepting all applicable security patches with or without the support of the Contractor personnel. If patching can only be completed by the Contractor, the Contractor shall commit the resources needed to patch all applicable devices at all VA locations. If unique patching instructions or packaging is needed, the Contractor shall provide the necessary information in conjunction with the validation/testing of the patch. The Contractor shall apply security patches within 30 business days of the patch release and have a formal tracking process for any security patches not implemented to include explanation when a device cannot be patched.
- f. The Contractor shall provide devices able to install and maintain VA-approved antivirus capabilities with the capability to quarantine files and be updated as needed in response to incidents. Alternatively, a VA-approved whitelisting application may be used when the Contractor cannot install an anti-virus / anti-malware application.

- g. The Contractor shall verify and document all software embedded within the device does not contain any known viruses or malware before delivery to or installation at a VA location.
- h. Devices and other equipment or systems containing media (hard drives, optical disks, solid state, and storage via chips/firmware) with VA sensitive information will be returned to the Contractor with media removed. When the contract requires return of equipment, the options available to the Contractor are the following:
 - (1) The Contractor shall accept the system without the drive, firmware and solid state.
 - (2) VA's initial device purchase includes a spare drive or other replacement media which must be installed in place of the original drive at time of turn-in; or
 - (3) Due to the highly specialized and sometimes proprietary hardware and software associated with the device, if it is not possible for VA to retain the hard drive, firmware, and solid state, then:
 - (a) The equipment Contractor shall have an existing BAA if the device being traded in has sensitive information stored on it and hard drive(s) from the system are being returned physically intact.
 - (b) Any fixed hard drive, Complementary Metal-Oxide-Semiconductor (CMOS), Programmable Read-Only Memory (PROM), solid state and firmware on the device must be non-destructively sanitized to the greatest extent possible without negatively impacting system operation. Selective clearing down to patient data folder level is recommended using VA approved and validated overwriting technologies/methods/tools. Applicable media sanitization specifications need to be pre-approved and described in the solicitation, contract, or order.

B14. DATA CENTER PROVISIONS

- a. The Contractor shall ensure the VA network is accessed by in accordance with VA Directive 6500 and IAM security processes specified in the VA Information Security Knowledge Service.
- b. The Contractor shall ensure network infrastructure and data availability in accordance with VA information system business continuity procedures specified in the VA Information Security Knowledge Service.

Supply Chain GUI Overlay
VA-26-00023382

- c. The Contractor shall ensure any connections to the internet or other external networks for information systems occur through managed interfaces utilizing VA approved boundary protection devices (e.g., internet proxies, gateways, routers, firewalls, guards or encrypted tunnels).
- d. The Contractor shall encrypt all traffic across the segment of the Wide Area Network (WAN) it manages, and no unencrypted Out of Band (OOB) Internet Protocol (IP) traffic will traverse the network.
- e. The Contractor shall ensure tunnel endpoints are routable addresses at each VA operating site.
- f. The Contractor shall secure access from Local Area Networks (LANs) at co-located sites in accordance with VA TIC Reference Architecture, VA Directive and Handbook 6513, and MOU/ISA process specified in the VA Information Security Knowledge Service.

SCHEDULE FOR DELIVERABLES

Note: Days used in the table below refer to calendar days unless otherwise stated. Deliverables with due dates falling on a weekend or holiday shall be submitted the following Government work day after the weekend or holiday.

(Indicate delivery dates in terms of number of days after (DAC) Contract award. A Mark For and Ship To address (including Inspection/Acceptance requirements) must be provided for all product deliverables. Electronic delivery of software or paper deliverables should be the norm unless otherwise stated. Email addresses must be provided. Although email addresses are provided below for all POC's, table must be clear as to who receives the deliverables.)

Task	Deliverable ID	Deliverable Description
5.1.1	A	Contractor Project Management Plan Due Thirty (30) days after contract (DAC) and updated monthly thereafter. Electronic submission to: VA PM, COR Inspection: destination Acceptance: destination
5.1.2	A	Kickoff Meeting Agenda Draft agenda is due 5 days prior to Kickoff Meeting; Final agenda shall be distributed to all meeting attendees upon Government approval of final agenda. Electronic submission to: All Kickoff Meeting Attendees Inspection: destination Acceptance: destination
5.1.2	B	Kickoff Meeting Due Ten (10) days after contract (DAC). Minutes distributed 3 days after meeting. Electronic submission to: All Kickoff Meeting Attendees

Supply Chain GUI Overlay
VA-26-00023382

Task	Deliverable ID	Deliverable Description
		Inspection: destination Acceptance: destination
5.1.2	C	PowerPoint Presentation Initial draft due at the Kickoff Meeting. Updated presentation due at the conclusion of the Kickoff Meeting. Final Due 3 days after meeting. Electronic submission to: All Kickoff Meeting Attendees Inspection: destination Acceptance: destination
5.2.2.1	A	Technical Services Monthly Report Report is due NLT 1st day of the Month. Electronic submission to: COR, PM Inspection: destination Acceptance: destination
5.2.2.1	B	Role and Functionality-Based Training Materials Due 5 days before each patch version/release. Electronic submission to: COR, PM, ISO Inspection: destination Acceptance: destination
5.3	A	Perpetual GUI Licenses Licenses shall be delivered 5 days after exercise of Optional Task. Electronic submission to: VA PM, COR, Cyber Team, VAEC Team list others as necessary Inspection: destination Acceptance: destination
5.4	A	Interface between APAT and newly created modernized Logistics solution. Due by OT closeout Electronic submission to: VA PM, COR, CO, Product Owner (PO) Inspection: destination Acceptance: destination
5.5	A	Interface between APAT and EHRM/Cerner or newly created modernized Medical Records Management solution. Due by OT closeout Electronic submission to: VA PM, COR, CO, PO Inspection: destination Acceptance: destination
5.6	A	Interface between APAT and FMBT Due by OT closeout Electronic submission to: VA PM, COR, CO, PO Inspection: destination Acceptance: destination
6.2.2	A	Contractor Staff Roster Due 3 days after contract award and updated throughout the PoP. Electronic submission to: VA PM, COR, CO. Inspection: destination Acceptance: destination

POINTS OF CONTACT

VA Program Manager:

Name: TBD
Address: TBD
Voice: TBD
Email: TBD

Contracting Officer's Representative:

Name: TBD
Address: TBD
Voice: TBD
Email: TBD

Contracting Officer:

Name: Michael Weckesser
Address: 23 Christopher Way, Eatontown NJ 07724
Voice: 848-377-5052
Email: Michael.Weckesser@va.gov